

Hà Nội, ngày tháng năm 2026

THUYẾT MINH SÁNG KIẾN/GIẢI PHÁP

MỤC LỤC

...

(Mở tệp trong Word và nhấn Ctrl+A rồi F9 để cập nhật mục lục và số trang)

A. THÔNG TIN CHUNG

1. Tên sáng kiến/giải pháp: Secure Mail — Hệ thống mã hóa đầu cuối thư điện tử trên nền Gmail, bản địa hóa tiếng Việt, phục vụ giảng dạy và bảo đảm an toàn thông tin.

2. Thuộc lĩnh vực: Công nghệ thông tin — An toàn thông tin.

3. Họ và tên tác giả: [.....]

Năm sinh	[.....]
Tên cơ quan, đơn vị	[Khoa/Phòng] — Học viện Khoa học Quân sự
Cấp bậc	[.....]
Chức vụ	Giảng viên
Trình độ chuyên môn	[.....]
Số điện thoại	[.....]

4. Thời gian thực hiện: [..... / 2026] – [..... / 2026].

5. Sản phẩm bàn giao: phần mềm Secure Mail v0.3.0 (gói cài đặt kèm mã băm SHA-256), dự án phiên bản di động kèm thiết kế 12 màn hình Android, bộ 6 kịch bản kiểm chứng, 9 tài liệu vận hành bằng tiếng Việt.

B. NỘI DUNG CHÍNH CỦA SÁNG KIẾN/GIẢI PHÁP

1. Hiện trạng giải pháp đã biết

1.1. Vấn đề thực tế đặt ra

Tác giả là giảng viên trực tiếp giảng dạy An toàn thông tin trên không gian mạng. Từ công tác giảng dạy và hoạt động thường xuyên của đơn vị, hai nhu cầu cùng đặt ra một bài toán.

Bảo vệ nội dung trao đổi qua thư điện tử. Cần phân biệt rõ hai lớp bảo vệ, vì đây là điểm hay bị đồng nhất. *Mã hóa trên đường truyền* (TLS) bảo vệ dữ liệu khi đi qua mạng, nhưng kết thúc tại máy chủ nhà cung cấp — tại đó thư được giải mã để lưu trữ và lập chỉ mục. *Mã hóa đầu cuối* thì bản rõ chỉ tồn tại trên máy người gửi và người nhận. Với đơn vị, khác biệt này rất cụ thể: mọi tài liệu giảng dạy, đề thi chưa công bố, kết quả học tập, dữ liệu cá nhân học viên và trao đổi nghiệp vụ gửi qua thư điện tử thông thường đều nằm ở **dạng rõ** trên hạ tầng mà đơn vị không kiểm soát, trong toàn bộ thời gian lưu trữ.

Thực hành mật mã ứng dụng trong giảng dạy. Học viên nắm được lý thuyết mật mã khóa công khai nhưng không nối được với thao tác thực tế: sinh khóa, phân phối khóa công khai, đối chiếu dấu vân tay, phát hiện một chữ ký không hợp lệ. Nguyên nhân nằm ở công cụ — mọi phần mềm mã hóa đầu cuối phổ biến đều chỉ có giao diện tiếng Anh với hệ thuật ngữ chưa chuẩn hóa. Học viên phải vượt đồng thời rào cản khái niệm và rào cản ngôn ngữ.

1.2. Bốn điều kiện ràng buộc

Từ thực tế trên, tác giả xác định giải pháp phải đồng thời thỏa mãn bốn điều kiện. Đây là khung phân tích của tác giả, và được dùng làm tiêu chí đánh giá các giải pháp đã biết:

1. **Không phải đổi nhà cung cấp thư điện tử** — nếu không, chi phí chuyển đổi và rủi ro gián đoạn công tác vượt quá lợi ích.
2. **Không cần hạ tầng mới** — không máy chủ, không hệ thống chứng thực số.
3. **Dùng được bằng tiếng Việt, không đòi hỏi chuyên môn mật mã.**

4. Không tạo phụ thuộc mới vào bên thứ ba — nếu không, chỉ là chuyển sự phụ thuộc từ chỗ này sang chỗ khác.

Nơi lỏng bất kỳ điều kiện nào cũng làm giải pháp mất giá trị thực tế.

1.3. Khảo sát các giải pháp đã biết

Nhóm A — Dịch vụ thư điện tử bảo mật (Proton Mail, Tuta). *Ưu điểm:* trải nghiệm liền mạch, có ứng dụng di động. *Nhược điểm chưa khắc phục:* buộc chuyển toàn bộ hộp thư sang nhà cung cấp nước ngoài; khóa riêng tư lưu trên máy chủ của họ nên nhà cung cấp nằm trong ranh giới tin cậy; bài toán chủ quyền dữ liệu không được giải mà chỉ đổi chỗ; Tuta dùng định dạng riêng nên không liên thông với công cụ mật mã khác; không có tiếng Việt.

Nhóm B — S/MIME. *Ưu điểm:* là chuẩn công nghiệp, tích hợp sẵn trong nhiều máy khách thư. *Nhược điểm chưa khắc phục:* đòi hỏi hạ tầng khóa công khai với tổ chức chứng thực, quy trình cấp và thu hồi chứng thư cho từng người dùng; không dùng được với giao diện web; chi phí và thủ tục làm cho việc triển khai ở quy mô một bộ môn trở nên không khả thi.

Nhóm C — GnuPG kết hợp máy khách thư truyền thống. *Ưu điểm:* mạnh, trưởng thành, hoàn toàn tự chủ. *Nhược điểm chưa khắc phục:* rào cản sử dụng rất cao — đây là nguyên nhân được ghi nhận rộng rãi khiến mã hóa thư điện tử không phổ cập ngoài giới chuyên môn; không tích hợp giao diện web; chỉ có tiếng Anh.

Nhóm D — Tiện ích mã hóa cho trình duyệt (Mailvelope, FlowCrypt). Đây là nhóm gần nhất với hướng tiếp cận đúng: giữ nguyên nhà cung cấp thư, bổ sung lớp mã hóa trong trình duyệt. Nhóm này **đáp ứng điều kiện 1 và 2**, nhưng không đáp ứng điều kiện 3 và 4. Các nhược điểm dưới đây được tác giả kiểm chứng trực tiếp trên mã nguồn, không dựa vào tài liệu quảng bá.

Bảng 1. Nhược điểm chưa khắc phục của nhóm D, kiểm chứng trên mã nguồn

Nhược điểm	Bảng chứng kiểm chứng
Không có tiếng Việt. Mailvelope 6.3.0 có 15 ngôn ngữ, không có tiếng Việt. FlowCrypt không có cơ chế đa ngữ.	Thư mục <code>locales/</code> của Mailvelope tại commit <code>ffaa27af</code> ; thư mục <code>extension/</code> của kho FlowCrypt/flowcrypt-browser không chứa <code>_locales/</code> , kiểm tra 08/9/2026
Không cho phép chọn ngôn ngữ. Ngôn ngữ khóa cứng theo trình duyệt vì mọi chuỗi phân	<code>src/lib/ll10n.js:export const</code>

giải qua chrome.i18n.	get = chrome.i18n.getMessage;
Mặc định tra cứu máy chủ khóa ở nước ngoài. Ba cơ chế bật sẵn; mỗi lần soạn thư cho địa chỉ mới là một truy vấn ra ngoài, để lộ quan hệ liên lạc.	src/res/defaults.json: mvelo_tofu_lookup, oks_lookup, wkd_lookup đều true
Có thư viện đo lường từ xa trong gói cài đặt. Tính năng tắt bằng một hằng số, nhưng SDK và địa chỉ máy chủ vẫn nằm trong gói phát hành.	src/lib/analytics.js dòng 6 và 70; chuỗi cleaninsights xuất hiện 9 lần trong gói đã biên dịch
Chặn tài khoản Google Workspace bằng kiểm tra giấy phép thương mại. Gửi tên miền và mã băm định danh tài khoản Google về máy chủ nhà phát triển; không có giấy phép thì từ chối chức năng.	src/modules/gmail.js: checkLicense, requestLicense, MVELO_BILLING_API_HOST
Luồng xác thực OAuth không có PKCE. Bí mật client ghi thẳng trong mã nguồn, không có cơ chế bù trừ.	src/modules/gmail.js: getAuthCode không có tham số code_challenge
Định danh tiện ích không cố định. Không khai báo khóa trong manifest nên Chrome sinh mã định danh từ đường dẫn cài đặt — mỗi máy một URI chuyển hướng khác nhau, không đăng ký trước được.	src/chrome/manifest.json: không có trường key

Nhóm E — Sản phẩm mật mã chuyên dụng của cơ quan có thẩm quyền. Cần trả lời thẳng câu hỏi tự nhiên nhất trong bối cảnh quân đội. Hai thứ phục vụ **hai lớp thông tin khác nhau và không cạnh tranh**. Với thông tin thuộc danh mục bí mật nhà nước, sản phẩm mật mã của cơ quan có thẩm quyền là **bắt buộc theo quy định pháp luật** và Secure Mail không thay thế (mục 4.đ). Với lớp thông tin còn lại — chiếm phần lớn khối lượng trao đổi hằng ngày — việc áp dụng quy trình và sản phẩm mật mã chuyên dụng cho toàn bộ là quá tải về thủ tục và nguồn lực; thực tế dẫn tới lớp này được gửi bằng thư điện tử thông thường, tức **không được bảo vệ gì cả**. Ngoài ra, sản phẩm chuyên dụng không phù hợp làm học cụ: học viên không tiếp cận được mã nguồn, không quan sát được cơ chế bên trong.

1.4. Kết luận về hiện trạng

Bảng 2. Đối chiếu năm nhóm giải pháp với bốn điều kiện

Điều kiện	A	B	C	D	E
1. Giữ nguyên nhà cung cấp thư	Không	Có	Có	Có	Có
2. Không cần	Có	Không	Có	Có	Không

hạ tầng mới					
3. Dùng được bằng tiếng Việt, không cần chuyên môn mật mã	Không	Không	Không	Không	Không
4. Không tạo phụ thuộc mới vào bên thứ ba	Không	Một phần	Có	Không	Có

Khoảng trống là rõ ràng: **hướng tiếp cận của nhóm D là đúng, nhưng chưa có ai làm công việc kỹ thuật để biến nó thành sản phẩm triển khai được trong điều kiện của một đơn vị Việt Nam.** Đó là bài toán mà sáng kiến này giải.

2. Mục đích của giải pháp

Sáng kiến nhằm giải quyết bốn vấn đề cụ thể phát sinh từ thực tế:

5. Đưa mã hóa đầu cuối vào thao tác thường ngày mà không thay đổi hạ tầng.

Người dùng tiếp tục dùng hộp thư và trình duyệt đang có.

6. Xóa rào cản ngôn ngữ trong công cụ mật mã.

Toàn bộ giao diện, thông báo lỗi và cảnh báo an toàn bằng tiếng Việt với hệ thuật ngữ nhất quán; người dùng chọn được ngôn ngữ độc lập với trình duyệt.

7. Đưa quyền kiểm soát mô hình tin cậy về đơn vị.

Việc xác nhận "khóa công khai này đúng là của người này" do đơn vị chịu trách nhiệm qua kênh nội bộ, không giao phó cho máy chủ bên thứ ba và không để lộ quan hệ liên lạc ra ngoài.

8. Bảo đảm tính kiểm chứng được.

Mọi khẳng định về an toàn phải kiểm tra lại được bằng công cụ, trên chính bản phát hành. Trong an toàn thông tin, một tuyên bố không kiểm chứng được thì không có giá trị.

Mục đích phái sinh nhưng quan trọng với công tác giảng dạy: **tạo ra một học cụ thực tế** để học viên thực hành mật mã ứng dụng trên chính công cụ đang dùng trong công việc, với hệ thuật ngữ thống nhất giữa bài giảng và phần mềm.

3. Mô tả giải pháp

a) Nguyên lý của giải pháp

Nguyên lý mật mã

Giải pháp dựa trên **mật mã lai (hybrid cryptography)** theo chuẩn OpenPGP: mỗi người dùng có một cặp khóa; khi gửi thư, hệ thống sinh khóa phiên đối xứng ngẫu nhiên, mã hóa nội dung bằng AES-256, rồi mã hóa khóa phiên bằng khóa công khai của từng người nhận; đồng thời ký số nội dung bằng khóa riêng tư người gửi. Cơ chế kiểm tra toàn vẹn bảo đảm mọi sửa đổi lên bản mã đều bị phát hiện và bản mã bị từ chối, thay vì cho ra bản rõ sai.

Nguyên lý kiến trúc: dịch chuyển ranh giới tin cậy

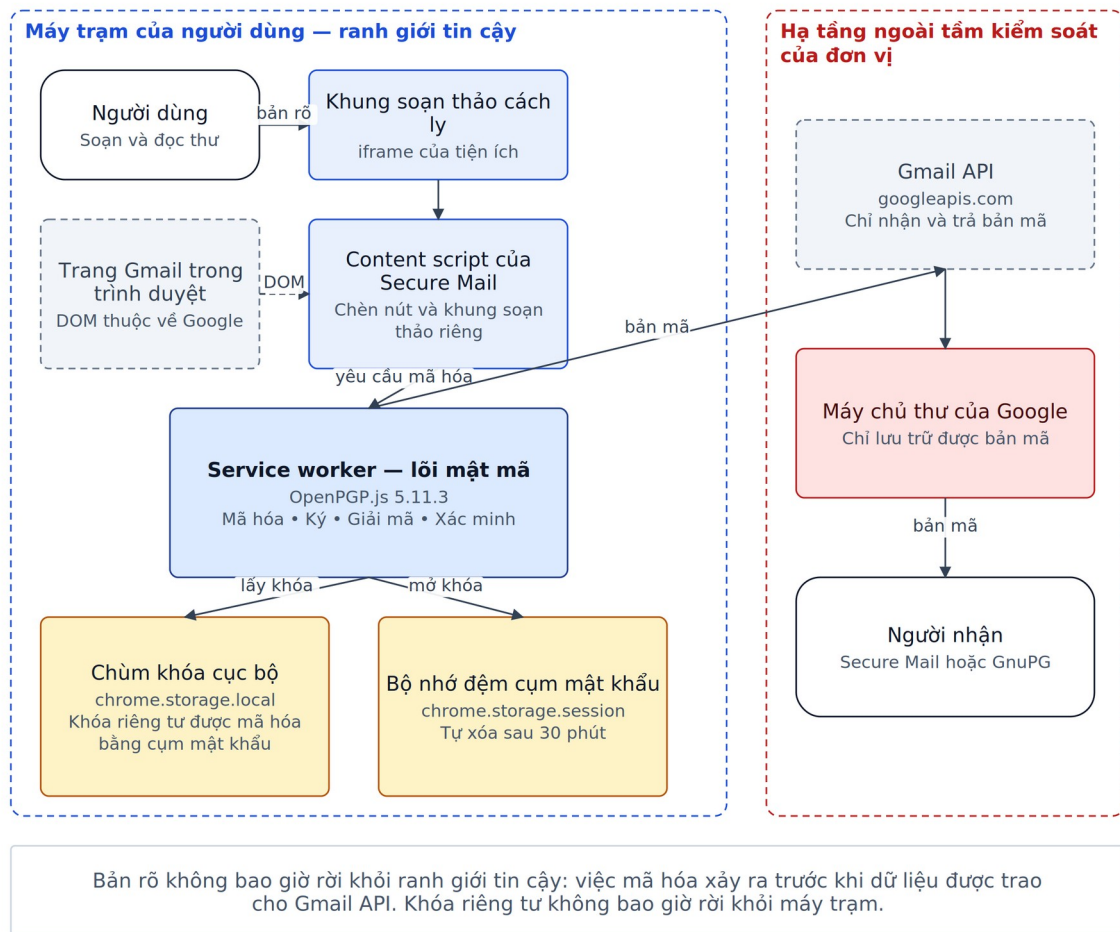
Đây là nguyên lý cốt lõi do tác giả xác định, và nó chi phối mọi quyết định thiết kế còn lại.

Trong mô hình thư điện tử thông thường, ranh giới tin cậy bao gồm cả máy chủ nhà cung cấp — người dùng buộc phải tin rằng nhà cung cấp không đọc, không rò rỉ, không bị xâm nhập. Trong thiết kế của Secure Mail, ranh giới tin cậy **chỉ gồm máy trạm của người dùng**; nhà cung cấp bị đẩy ra ngoài và được đối xử như một kênh truyền không tin cậy, chỉ vận chuyển và lưu trữ bản mã.

Ba hệ quả trực tiếp, và đây là cách nguyên lý được chuyển thành quyết định kỹ thuật:

- Khóa riêng tư **không được rời khỏi máy trạm** trong bất kỳ hoàn cảnh nào → loại bỏ mọi cơ chế đồng bộ khóa qua máy chủ (mục 3.b.2).
- Bản rõ phải được mã hóa **trước khi giao cho bất kỳ thành phần nào bên ngoài**, kể cả trước khi đưa vào ô soạn thảo của trang web nhà cung cấp → thiết kế khung soạn thảo cách ly (mục 3.b.1).
- Mọi kết nối ra ngoài là bề mặt tấn công tiềm tàng, phải được kiểm đếm, giải thích hoặc loại bỏ → toàn bộ mục 3.b.3.

Kiến trúc tổng thể Secure Mail trên nền Gmail



Hình 1. Kiến trúc tổng thể và vị trí của ranh giới tin cậy

Các yếu tố tác động đến giải pháp

Nền tảng trình duyệt. Manifest V3 của Chrome: mã nền chạy trong service worker có vòng đời ngắn, bị dừng khi rảnh — ảnh hưởng trực tiếp tới cách lưu trữ trạng thái và xử lý bộ nhớ đệm cụm mật khẩu.

Giao diện của nhà cung cấp thư. Giao diện web của Gmail thay đổi theo thời gian; phần chèn giao diện phải bám vào cấu trúc trang. Đây là điểm dễ tổn thương nhất về bảo trì, và là lý do tác giả tách hoàn toàn phần lõi mật mã khỏi phần chèn giao diện.

Chính sách của nhà cung cấp định danh. Truy cập Gmail API qua OAuth 2.0 đòi hỏi đăng ký ứng dụng, phạm vi quyền và URI chuyển hướng cố định — ràng buộc này quyết định thiết kế tại mục 3.b.4.

Năng lực người dùng. Người dùng không phải chuyên gia mật mã. Mọi thao tác đòi hỏi hiểu biết kỹ thuật là một điểm mà giải pháp sẽ thất bại trong thực tế. Nguyên

tắc thiết kế: **mặc định phải an toàn, và mặc định phải dùng được ngay mà không cần cấu hình.**

b) Các nội dung chủ yếu

Quyết định nền tảng: thiết kế hệ thống, không chế tạo lại lỗi mật mã

Cần nêu rõ quyết định kỹ thuật nền tảng và lý do trước, vì nó quyết định cách đánh giá toàn bộ sáng kiến.

Trong an toàn thông tin, tự viết lại phần lỗi mật mã là một trong những sai lầm được cảnh báo nhiều nhất. Một thư viện đúng về thuật toán vẫn có thể sai về hiện thực: rò rỉ qua thời gian thực thi, xử lý sai trường hợp biên, sinh số ngẫu nhiên yếu, quản lý bộ nhớ không an toàn — những lỗi chỉ bộc lộ sau nhiều năm được cộng đồng soi xét. **Chế tạo lại lỗi mật mã để tăng tính "tự làm" sẽ làm giảm độ an toàn thực tế của sản phẩm, tức đi ngược chính mục tiêu của sáng kiến.**

Vì vậy tác giả áp dụng cách làm của kỹ thuật hệ thống: **thiết kế hệ thống, và lựa chọn linh kiện đã được kiểm chứng cho những vị trí mà việc tự chế tạo là phản kỹ thuật.** Linh kiện được chọn là thư viện mật mã OpenPGP.js 5.11.3 và nền tảng tiện ích Mailvelope 6.3.0 (giấy phép AGPL-3.0), sau khi đánh giá theo bốn điều kiện tại mục 1.2. Nguồn gốc được ghi nhận đầy đủ trong SOURCE_SNAPSHOT.md, LICENSE và THIRD_PARTY_NOTICES.md — vừa là yêu cầu bắt buộc của giấy phép, vừa là chuẩn mực liên chính khoa học.

Đóng góp của tác giả nằm ở thiết kế hệ thống xung quanh linh kiện đó: mô hình tin cậy, kiến trúc bản địa hóa và thuật toán phân giải ngôn ngữ, thiết kế luồng xác thực, kiến trúc mở rộng di động, và phương pháp kiểm chứng. Bảy nội dung dưới đây trình bày từng phần.

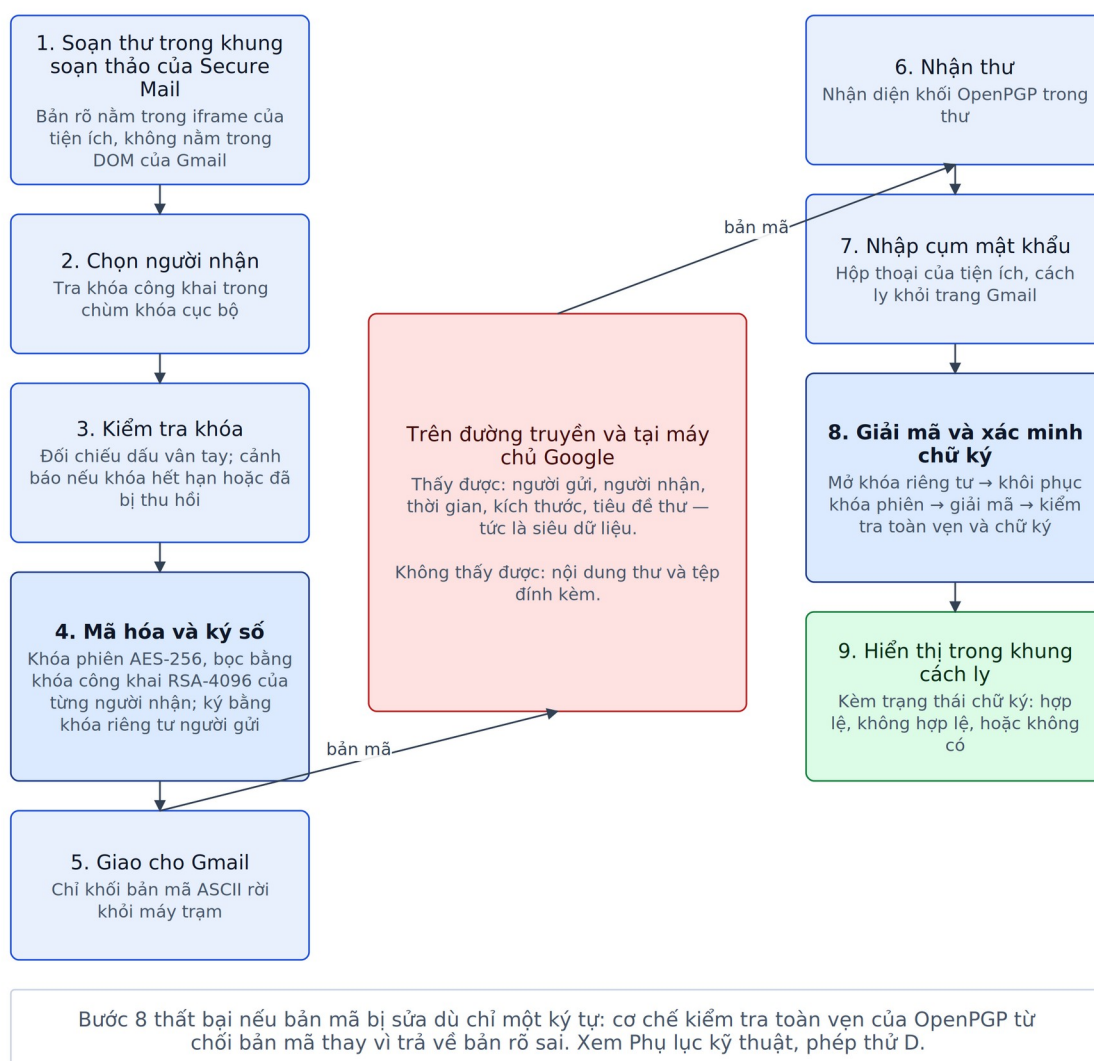
Rà soát cho thấy linh kiện được chọn, ở trạng thái nguyên bản, **không triển khai được** trong đơn vị: tài khoản Google Workspace bị chặn, luồng xác thực thất bại vì định danh không ổn định, không có tiếng Việt, mặc định rò rỉ quan hệ liên lạc, và gói cài đặt chứa thư viện đo lường từ xa. Toàn bộ những rào cản này đã được xử lý.

3.b.1. Thiết kế cách ly bản rõ trong giao diện Gmail

Một đoạn mã được nạp vào trang Gmail, nhận diện ô soạn thư và các thư chứa khối OpenPGP, rồi chèn thêm nút điều khiển. **Toàn bộ thao tác mật mã không diễn ra trong đoạn mã này** mà được chuyển cho service worker — môi trường tách biệt hoàn toàn khỏi trang web.

Đây là điểm thiết kế quan trọng nhất về an toàn. Đoạn mã chèn vào trang Gmail chạy trong cùng nguồn gốc với trang của Google; nếu bản rõ hoặc khóa đi qua đó, một lỗ hổng trên trang Gmail sẽ trở thành lỗ hổng của Secure Mail. Do đó: bản rõ được nhập trong **khung soạn thảo cách ly** thuộc về tiện ích; bản rõ khi giải mã hiển thị trong **khung cách ly**; cụm mật khẩu nhập trong **hộp thoại của tiện ích**.

Luồng xử lý một bức thư mã hóa (gửi và nhận)



Hình 2. Luồng xử lý một bức thư mã hóa, từ khi soạn đến khi người nhận đọc được

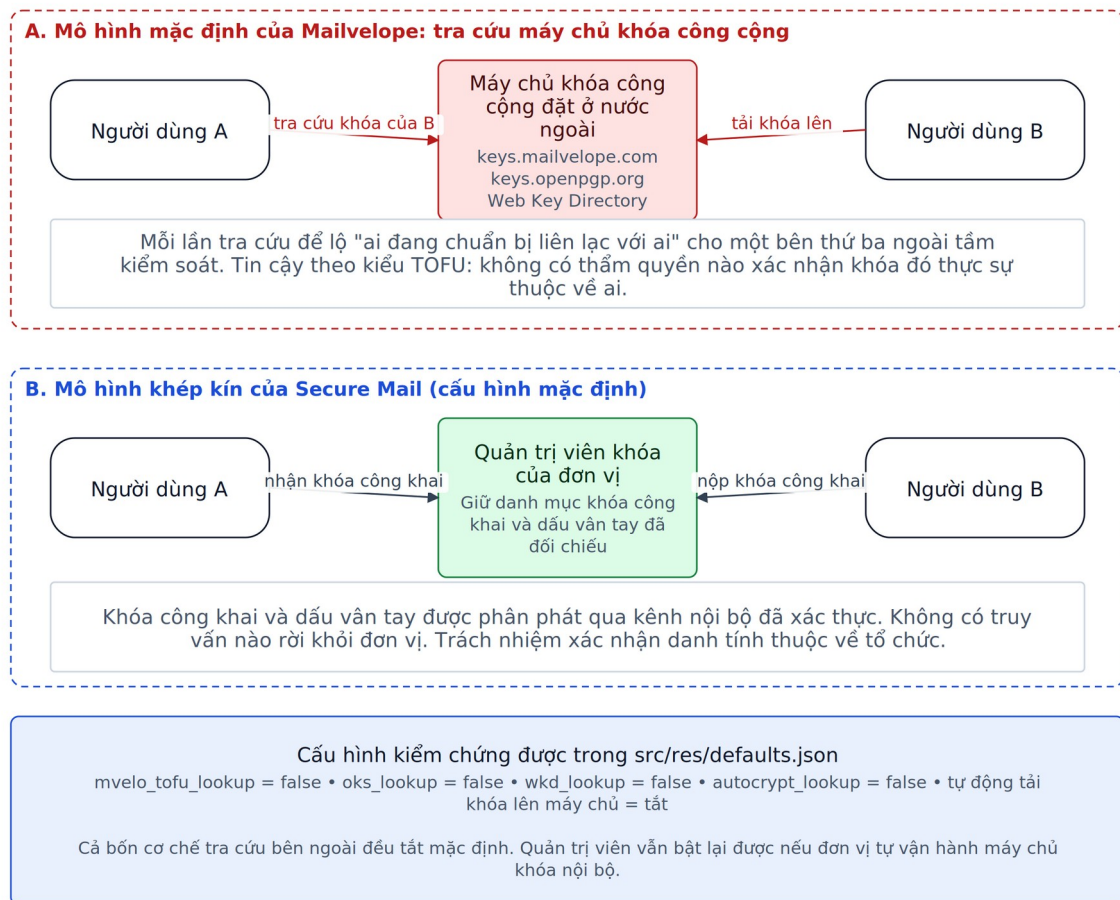
Từ góc nhìn của Google, một bức thư gửi qua Secure Mail chỉ là khối văn bản không đọc được. Google vẫn thấy **siêu dữ liệu** — người gửi, người nhận, thời gian, kích thước, tiêu đề — vì đó là thông tin giao thức thư điện tử bắt buộc để lộ nhằm định tuyến. Giới hạn này được nêu rõ tại mục 4.đ.

3.b.2. Mô hình tin cậy khép kín do đơn vị kiểm soát

Vấn đề. Mật mã khóa công khai giải được bài toán bí mật nhưng để lại bài toán khó hơn: *làm sao biết khóa công khai này đúng là của người kia?* Nếu kẻ tấn công đưa được khóa của mình vào chỗ khóa người nhận, hẳn đọc được toàn bộ thư — mọi thuật toán mạnh đều vô nghĩa. Lĩnh kiện nền tảng giải bài toán này bằng tra cứu máy chủ khóa công cộng theo mô hình TOFU, có hai nhược điểm nghiêm trọng trong bối cảnh đơn vị: **rò rỉ siêu dữ liệu quan hệ** — mỗi truy vấn thông báo cho một máy chủ nước ngoài rằng "người này sắp liên lạc với người kia", mà với một cơ quan thì tập hợp quan hệ liên lạc có giá trị tình báo độc lập với nội dung; và **không có thẩm quyền xác nhận** — TOFU chỉ ghi nhận, không ai chịu trách nhiệm.

Thiết kế của tác giả. Chuyển sang **mô hình phân phối khóa khép kín**: tắt toàn bộ bốn cơ chế tra cứu bên ngoài, và giao trách nhiệm xác nhận danh tính cho đơn vị — nơi vốn đã có thẩm quyền và quy trình để làm việc đó.

Hai mô hình phân phối khóa công khai



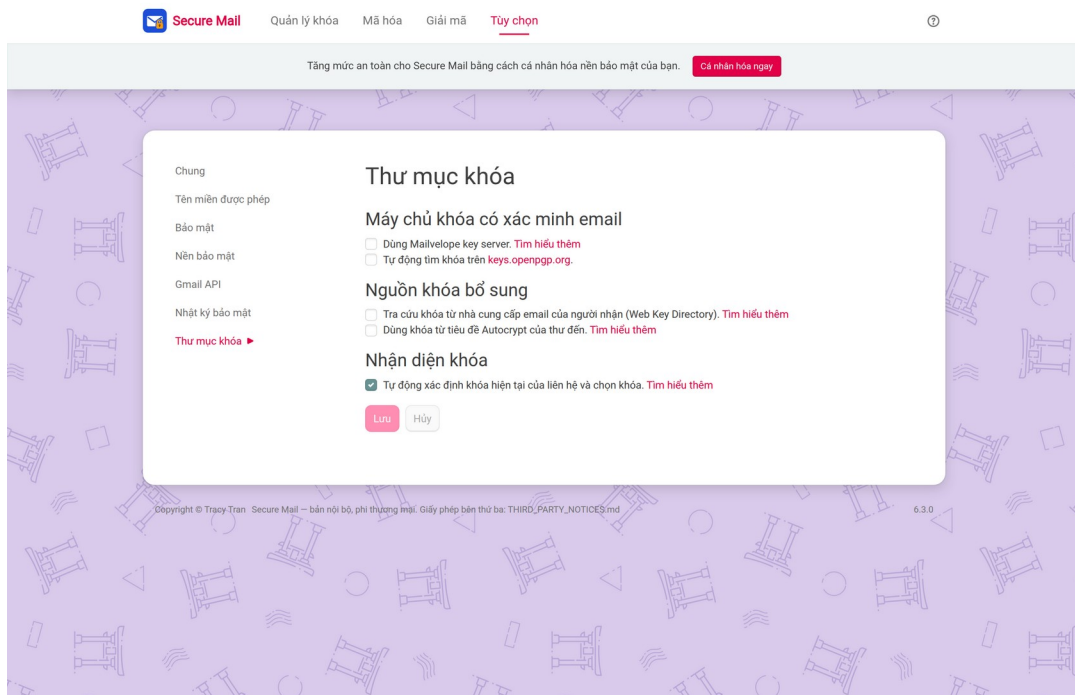
Hình 3. Hai mô hình phân phối khóa công khai

Quy trình quản trị đi kèm do tác giả xây dựng và tài liệu hóa bằng tiếng Việt, kèm mẫu danh mục khóa dạng CSV:

9. Người dùng sinh cặp khóa trên máy mình. **Khóa riêng tư không bao giờ rời khỏi máy đó.**
10. Người dùng gửi **khóa công khai và dấu vân tay** cho quản trị viên qua kênh nội bộ đã xác thực.
11. Quản trị viên **đối chiếu dấu vân tay trực tiếp** với người dùng, ghi vào danh mục khóa của đơn vị.
12. Quản trị viên phát hành danh mục khóa cho các thành viên.

Nguyên tắc cốt lõi: **quản trị viên chỉ quản lý khóa công khai và dấu vân tay, không bao giờ giữ khóa riêng tư của người dùng.** Nếu quản trị viên giữ khóa riêng tư thì mô hình mã hóa đầu cuối sụp đổ — quản trị viên trở thành một điểm đọc được mọi thư. Nguyên tắc này được tác giả đưa thẳng vào giao diện, bằng tiếng Việt, tại

màn hình thiết lập ban đầu, để người dùng biết rằng bất kỳ yêu cầu nộp khóa riêng tư nào cũng là dấu hiệu bất thường.



Hình 4. Màn hình Thư mục khóa: cả bốn cơ chế tra cứu bên ngoài đều ở trạng thái tắt

Thiết kế **không xóa bỏ** khả năng dùng máy chủ khóa: nếu về sau đơn vị tự vận hành máy chủ khóa nội bộ hoặc Web Key Directory trên tên miền của mình, quản trị viên bật lại được. Đây là lựa chọn có ý thức — giữ khả năng mở rộng, đặt mặc định ở trạng thái an toàn nhất.

3.b.3. Cắt bỏ phụ thuộc vào bên thứ ba

Nguyên lý tại mục 3.a đòi hỏi mọi kết nối ra ngoài phải được kiểm đếm và giải thích. Rà soát toàn bộ mã nguồn phát hiện **hai kênh liên lạc ra bên thứ ba mà người dùng không nhận biết được và không thể loại bỏ bằng cấu hình**. Tác giả quyết định gỡ bỏ cả hai **khởi mã nguồn**, không phải chỉ tắt bằng tùy chọn.

Thư viện đo lường từ xa. Linh kiện nền tảng nhúng SDK đo lường trở tới một máy chủ thống kê, kèm màn hình mời người dùng bật báo cáo; tính năng bị vô hiệu bằng một hằng số biên dịch nhưng SDK, định nghĩa chiến dịch thu thập và địa chỉ máy chủ vẫn nằm nguyên trong gói phát hành. Với sản phẩm dùng trong đơn vị, **"đang tắt"** và **"không tồn tại"** là hai mức bảo đảm khác nhau về bản chất: một hằng số có thể bị bật lại bởi một lần cập nhật, và người thẩm định không phân biệt được "tắt"

với "không có" nếu không đọc mã nguồn. Mô-đun được thay bằng bản rỗng giữ nguyên danh sách hàm xuất; gói phụ thuộc bị gỡ; màn hình xin phép và mục cài đặt tương ứng bị gỡ.

Cơ chế kiểm tra giấy phép thương mại. Đây là thay đổi có tác động triển khai lớn nhất. Với tài khoản thuộc miền Google Workspace — chính là cấu hình một cơ quan sẽ dùng — linh kiện nền tảng gửi tên miền và mã băm SHA-256 của định danh tài khoản Google về máy chủ cấp phép của nhà phát triển; không có giấy phép thì **từ chối thực hiện chức năng**. Hai lý do khiến cơ chế này không thể tồn tại: về **chủ quyền dữ liệu**, nó gửi một định danh tổ chức và một biệt danh ổn định của từng người dùng ra bên thứ ba trong mỗi lần cấp quyền; về **tính sẵn sàng**, một cơ quan dùng tên miền Workspace sẽ không đọc được thư của chính mình mỗi khi máy chủ cấp phép không truy cập được. **Khả năng đọc dữ liệu đã mã hóa của mình không được phép phụ thuộc vào một dịch vụ thương mại bên ngoài.**

Kiểm chứng. Việc gỡ bỏ được kiểm chứng bằng kịch bản do tác giả xây dựng, chạy trên **bản đã biên dịch** — kiểm tra sản phẩm thật, không phải kiểm tra ý định trong mã nguồn.

Bảng 3. Kiểm toán bề mặt mạng, đo trên gói phát hành

Điểm cuối bên thứ ba	Trước cải tạo	Bản v0.3.0
Thư viện đo lường từ xa (cleaninsights)	9 lần xuất hiện	0
Máy chủ thống kê (metrics.cleaninsights.org)	có	0
Máy chủ cấp phép (license.mailvelope.com)	1 lần xuất hiện	0
Trang bán giấy phép	1 lần xuất hiện	0
Kết luận		ĐẠT — 4/4

Kịch bản đồng thời liệt kê **toàn bộ** điểm phát sinh kết nối mạng còn lại, để người thẩm định đối chiếu thay vì phải tin: `accounts.google.com`, `oauth2.googleapis.com`, `www.googleapis.com` (bật — là tính năng đang dùng); `keys.mailvelope.com`, `keys.openpgp.org`, tra cứu theo tên miền người nhận (tắt mặc định). Nói cách khác, ở **cấu hình mặc định**, ngoài chính Gmail — dịch vụ mà

người dùng chủ động chọn — sản phẩm không liên lạc với bất kỳ máy chủ nào khác.

3.b.4. Thiết kế lại luồng xác thực Gmail API

Linh kiện nền tảng có hai vấn đề khiến việc triển khai thực tế không thực hiện được.

Vấn đề 1: định danh tiện ích không ổn định. Chrome sinh mã định danh cho tiện ích cài ở chế độ nhà phát triển bằng cách băm **đường dẫn thư mục cài đặt**. Cùng một bản phát hành, cài ở hai máy khác nhau sẽ nhận hai mã định danh khác nhau. Mã này lại quyết định URI chuyển hướng OAuth, mà URI chuyển hướng phải đăng ký trước với Google — không thể đăng ký trước một giá trị thay đổi theo từng máy. Đây là nguyên nhân gốc của lỗi `redirect_uri_mismatch`.

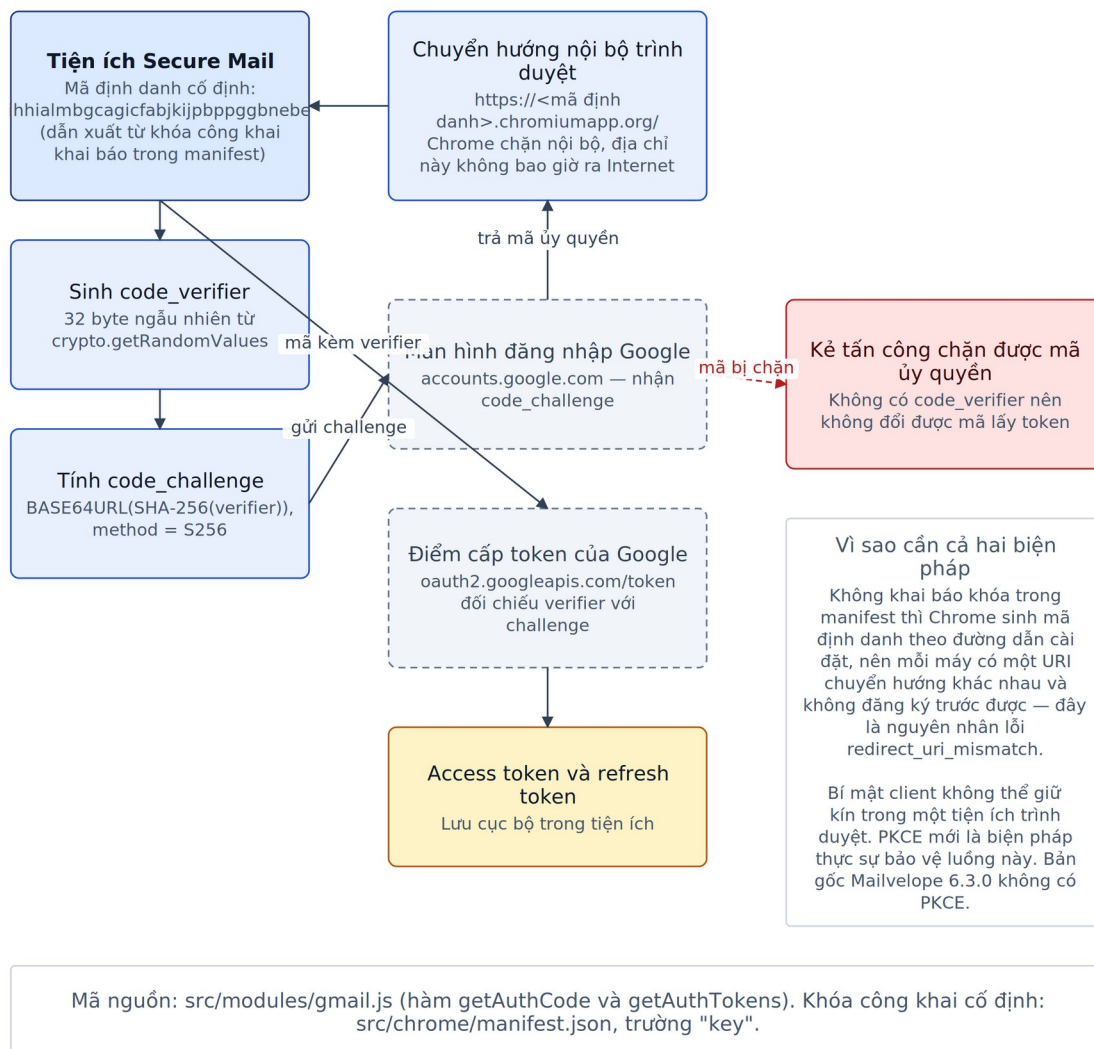
Thiết kế của tác giả: khai báo khóa công khai RSA cố định trong manifest, để Chrome dẫn xuất mã định danh từ khóa thay vì từ đường dẫn. Mã định danh trở thành **hằng số triển khai** trên mọi máy — đăng ký một lần với Google và dùng cho toàn đơn vị. Ngoài việc sửa lỗi, nó tạo thêm một lợi ích về an toàn: mã định danh trở thành đại lượng kiểm chứng được, quản trị viên đối chiếu giá trị hiển thị trong trình duyệt với giá trị công bố để phát hiện bản cài đặt giả mạo.

Vấn đề 2: luồng xác thực thiếu biện pháp bảo vệ. Linh kiện nền tảng ghi bí mật client thẳng vào mã nguồn. Đây không phải sơ suất mà là hệ quả bắt buộc: URI chuyển hướng dạng `chromiumapp.org` chỉ đăng ký được trên loại ứng dụng "Web application", mà Google coi loại này là bảo mật được và bắt buộc gửi kèm bí mật client. Nhưng một tiện ích trình duyệt **không thể** giữ bí mật — toàn bộ mã được đóng gói và ai cũng đọc được.

Thiết kế của tác giả: phản xạ thông thường khi thấy bí mật nằm trong mã nguồn là tìm cách giấu kỹ hơn — làm rối mã, tách tệp, mã hóa. Tất cả đều vô ích. Phân tích đúng phải bắt đầu từ câu hỏi *biện pháp này bảo vệ chống lại điều gì*: bí mật client tồn tại để chứng minh danh tính ứng dụng, điều mà tiện ích trình duyệt về nguyên tắc không làm được. Vì vậy giải pháp không phải giấu kỹ hơn, mà là **bổ sung một biện pháp khác thực sự phù hợp với mô hình đe dọa: PKCE (RFC 7636)** với phương thức S256. Mỗi lần xác thực, tiện ích sinh chuỗi ngẫu nhiên 32 byte, gửi mã băm SHA-256 của nó tới màn hình đăng nhập, và chỉ gửi chuỗi gốc khi đổi mã ủy quyền

lấy token. Mã ủy quyền bị gắn với một bí mật một lần dùng chưa từng rời khỏi tiện ích; kẻ chặn được mã ủy quyền **không đổi được** thành token.

Xác thực Gmail API: định danh tiện ích cố định kết hợp PKCE (RFC 7636)



Hình 5. Luồng xác thực Gmail API với định danh cố định và PKCE

Đồng thời tác giả đưa bí mật client ra khỏi hệ thống quản lý phiên bản, và sửa tham số login_hint để không mâu thuẫn với yêu cầu chọn tài khoản — lỗi khiến Google bỏ qua màn hình chọn tài khoản và tự động dùng tài khoản đang đăng nhập trong trình duyệt, một rủi ro thực tế với máy dùng chung.

3.b.5. Kiến trúc bản địa hóa và hệ thuật ngữ mật mã tiếng Việt

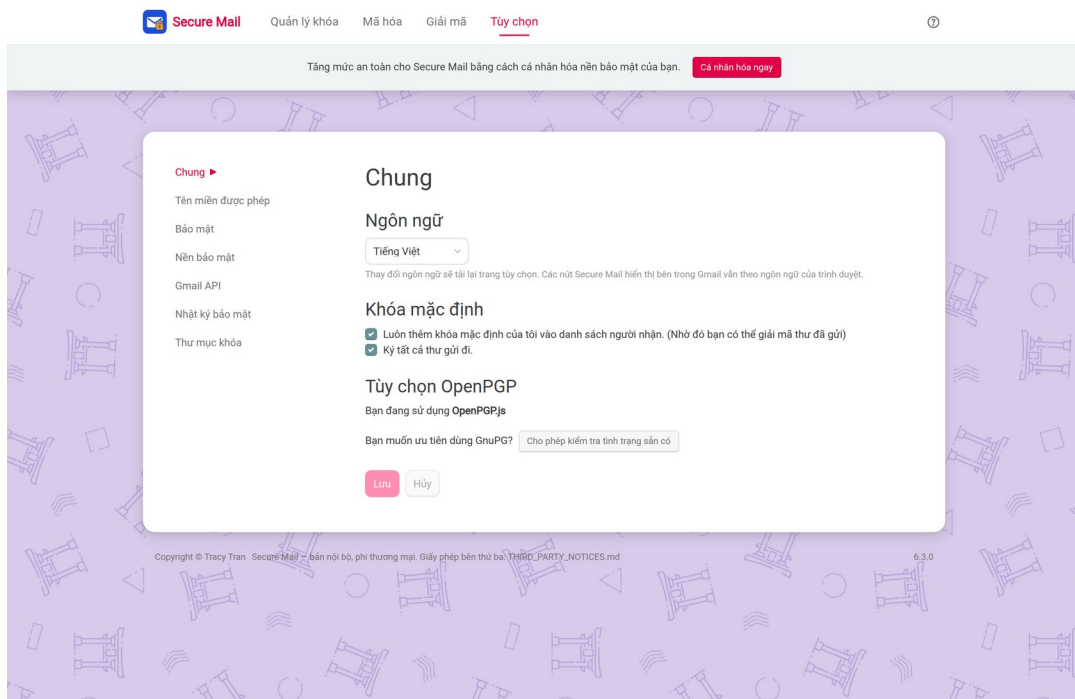
Vấn đề kiến trúc phải giải trước. Linh kiện nền tảng phân giải mọi chuỗi hiển thị qua chrome.i18n — cơ chế chọn ngôn ngữ **theo ngôn ngữ trình duyệt** và không

cho phép ứng dụng ghi đè. Chỉ thêm một thư mục ngôn ngữ là không đủ: người dùng dùng Chrome tiếng Anh, trường hợp rất phổ biến, sẽ không bao giờ thấy giao diện tiếng Việt. Ràng buộc thêm: bản chuỗi được nạp **đồng bộ** ngay khi mô-đun tải, trước khi bất kỳ lệnh chờ nào có thể chạy, nên không thể đọc lựa chọn từ kho lưu trữ bất đồng bộ của tiện ích.

Thuật toán phân giải do tác giả thiết kế. Đóng gói cả hai danh mục ngôn ngữ vào bản phát hành, đọc lựa chọn từ một kho lưu trữ đồng bộ theo nguồn gốc, và phân giải mỗi chuỗi theo bốn bước để **không bao giờ để lại ô trống trên giao diện**:

13. danh mục ngôn ngữ người dùng đã chọn;
14. nếu thiếu → lùi về danh mục tiếng Anh;
15. nếu vẫn thiếu → hỏi `chrome.i18n`, giữ nguyên khả năng hoạt động cho 14 ngôn ngữ còn lại;
16. nếu vẫn thiếu → hiển thị chính mã khóa của chuỗi, để một thiếu sót dịch thuật hiện ra rõ ràng thay vì biến thành ô trống khó truy vết.

Bước 3 đáng chú ý: thiết kế **bổ sung** khả năng chọn ngôn ngữ mà **không phá vỡ** cơ chế đa ngữ sẵn có.



Hình 6. Bộ chọn ngôn ngữ trong trang Tùy chọn, giao diện đang ở tiếng Việt

Hệ thuật ngữ mật mã tiếng Việt. Phần khó nhất của bản địa hóa một phần mềm mật mã không phải dịch câu mà là **chuẩn hóa thuật ngữ**: một khái niệm được dịch hai

cách ở hai màn hình sẽ dạy người dùng hai khái niệm khác nhau — hậu quả đặc biệt nghiêm trọng với sản phẩm đồng thời là học cụ. Tác giả xây dựng và áp dụng nhất quán bộ thuật ngữ sau trên toàn bộ 586 chuỗi.

Bảng 4. Hệ thuật ngữ mật mã tiếng Việt do tác giả xây dựng

Thuật ngữ gốc	Tiếng Việt	Căn cứ lựa chọn
private key	khóa riêng tư	Chọn "riêng tư" thay vì "bí mật" để tránh nhầm với "bí mật nhà nước"; nhấn vào tính sở hữu cá nhân — người dùng phải hiểu đây là thứ của riêng mình, không giao cho ai
public key	khóa công khai	
key pair	cặp khóa	
keyring	chùm khóa	Nhân điều hướng dùng "Quản lý khóa" vì đó là hành động người dùng thực hiện
passphrase	cụm mật khẩu	Phân biệt rõ với "mật khẩu" (password) — khác nhau về độ dài và mục đích
fingerprint	dấu vân tay	Giữ kèm từ gốc trong ngoặc ở lần xuất hiện đầu, để học viên nối được với tài liệu tiếng Anh
revoke / subkey	thu hồi / khóa phụ	
recovery sheet	phiếu khôi phục	
user ID	định danh người dùng	
encrypt / decrypt	mã hóa / giải mã	
sign / signature	ký / chữ ký số	
verify	xác minh	Phân biệt với "kiểm tra" (check)
backup / restore	sao lưu / khôi phục	

Tên riêng và tên chuẩn quốc tế (OpenPGP, GnuPG, Gmail, PKCE, WKD) giữ nguyên — dịch chúng sẽ làm người dùng mất khả năng tra cứu tài liệu gốc.

Kiểm toán chất lượng bản dịch bằng công cụ. Dịch 586 chuỗi thủ công chắc chắn phát sinh sai sót, và những sai sót nguy hiểm nhất lại không nhìn thấy khi đọc lướt. Tác giả xây dựng kịch bản kiểm toán kiểm tra năm nhóm lỗi: độ phủ; ô thay thế \$1, \$2 (mất một ô nghĩa là thông báo mất giá trị cần hiển thị); thẻ đánh dấu <0>...</0> (sai thẻ làm giao diện dựng sai cấu trúc); nhất quán thuật ngữ; chuỗi chưa dịch.

Kịch bản này đã phát hiện **sáu lỗi thực**, trong đó **hai lỗi ảnh hưởng trực tiếp tới an toàn**: một chuỗi hướng dẫn bỏ mất câu yêu cầu gửi khóa công khai và dấu vân tay cho quản trị viên qua kênh đã xác thực — tức bỏ mất chính bước bảo đảm tính xác thực của khóa; và một chuỗi bỏ mất khuyến cáo tự xác minh danh tính đối với liên hệ dùng nhà cung cấp thư khác. Cả sáu đã được sửa; kết quả sau khi sửa: **586/586 chuỗi, 0 lỗi chặn**. Chi tiết tại Phụ lục kỹ thuật, mục A.4.

Một giới hạn cần nêu rõ: các nút mà Secure Mail chèn **vào bên trong trang Gmail** vẫn theo ngôn ngữ trình duyệt, vì đoạn mã chèn vào trang chạy trong nguồn gốc của Gmail, nơi nó không đọc được vùng lưu trữ thuộc về tiện ích — cho nó đọc được sẽ phá vỡ chính sự cách ly ở mục 3.b.1. Đây là đánh đổi có ý thức nghiêng về phía an toàn; phạm vi ảnh hưởng nhỏ vì các nút này chỉ mang vài nhãn ngăn, còn toàn bộ nội dung người dùng thực sự phải đọc đều nằm trong các trang của tiện ích.

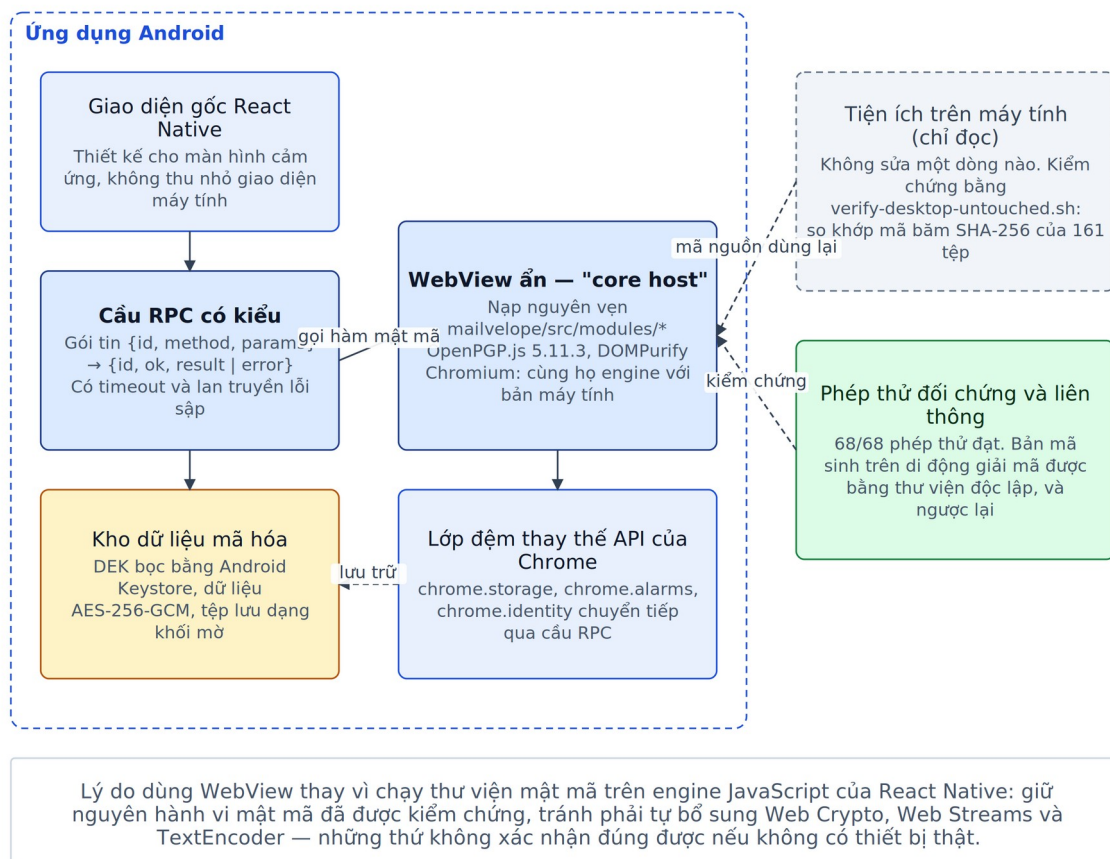
3.b.6. Kiến trúc mở rộng sang thiết bị di động

Tiện ích trình duyệt chỉ chạy trên máy tính; trình duyệt trên điện thoại không hỗ trợ tiện ích mở rộng. Nếu dừng ở bản máy tính, giải pháp mất tác dụng đúng vào lúc người dùng cần nhất — khi ở ngoài cơ quan.

Bài toán: xây dựng ứng dụng di động **mà không viết lại phần mật mã**, vì viết lại chính là điều đã lập luận phải tránh.

Kiến trúc do tác giả thiết kế: giao diện gốc React Native cho phần người dùng nhìn thấy, kết hợp một **WebView ẩn** làm nơi chạy lõi mật mã, hai bên nối qua một **cầu RPC có kiểu**.

kiến trúc phiên bản di động: tái sử dụng nguyên vẹn lõi mật mã đã kiểm chứng



Hình 7. Kiến trúc phiên bản di động

Cơ sở của lựa chọn: WebView trên Android là Chromium — cùng họ engine với trình duyệt mà bản máy tính đang chạy. Nhờ vậy Web Crypto, Web Streams và các thành phần nền tảng khác hoạt động **giống hệt**, và mã nguồn lõi mật mã được nạp vào **nguyên vẹn, không sửa một dòng**. Nếu thay vào đó chạy thư viện mật mã trên engine JavaScript của React Native, sẽ phải tự bổ sung một loạt thành phần nền tảng còn thiếu — mỗi thành phần là một chỗ có thể sai mà không kiểm chứng được nếu không có thiết bị thật.

Ba thành phần do tác giả xây dựng:

Hợp đồng RPC có kiểu — 22 phương thức. Ranh giới cố định giữa hai tầng: giao diện gọi vào, lỗi trả kết quả, không có đường tắt.

Bảng 5. Hợp đồng RPC giữa giao diện di động và lõi mật mã

Nhóm	Phương thức	Số lượng
Vòng đời ứng dụng	app.getVersion,	3

	<code>app.unlock, app.lock</code>	
Chùm khóa	<code>keyring.getKeys, getKeyData, getKeyDetails, generateKey, importKeys, removeKey, exportKeys, setDefaultKey, getDefaultKeyFpr</code>	9
Mật mã	<code>crypto.encryptMessage, decryptMessage, signMessage, verifyMessage, encryptFile, decryptFile</code>	6
Sao lưu	<code>backup.create, backup.restore</code>	2
Tùy chọn	<code>prefs.get, prefs.set</code>	2
Chiều ngược lại (lỗi gọi ứng dụng)	<code>storage.get/set/remove, pwd.request, log.uiLog</code>	5

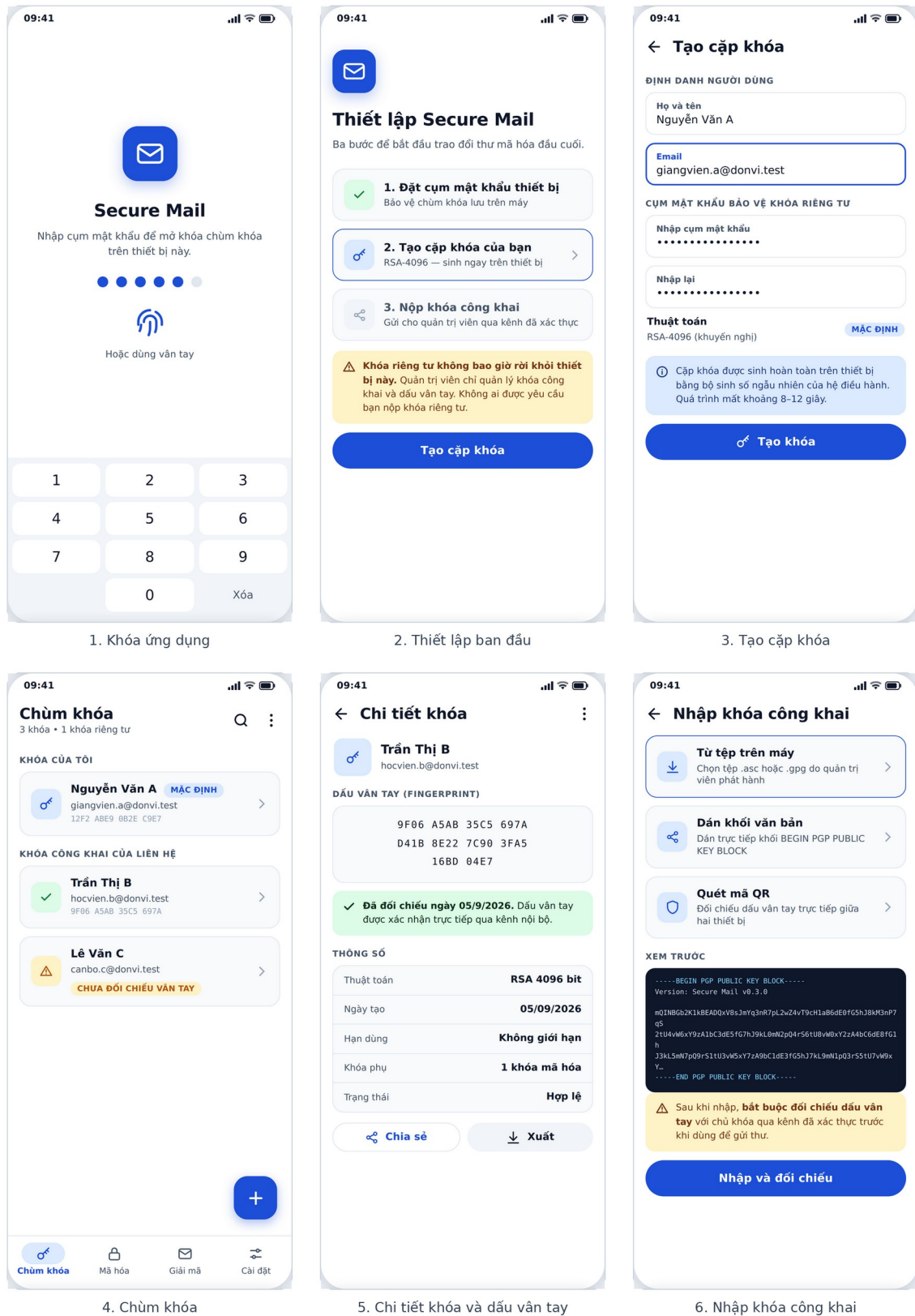
Phương thức `pwd.request` thể hiện rõ tư duy thiết kế: khi lỗi cần mở khóa riêng tư, nó **không tự hỏi người dùng** mà phát yêu cầu ngược về tầng giao diện. Nhờ vậy hộp thoại nhập cụm mật khẩu là thành phần gốc của Android, không phải một trang web trong WebView — người dùng nhập bí mật vào giao diện hệ điều hành thật.

Lớp đệm thay thế API của trình duyệt. Lỗi mật mã gọi các API riêng của tiện ích Chrome; trong WebView, chúng được thay bằng lớp đệm chuyển tiếp qua cầu RPC. Nhờ vậy lỗi không cần biết mình đang chạy ở đâu.

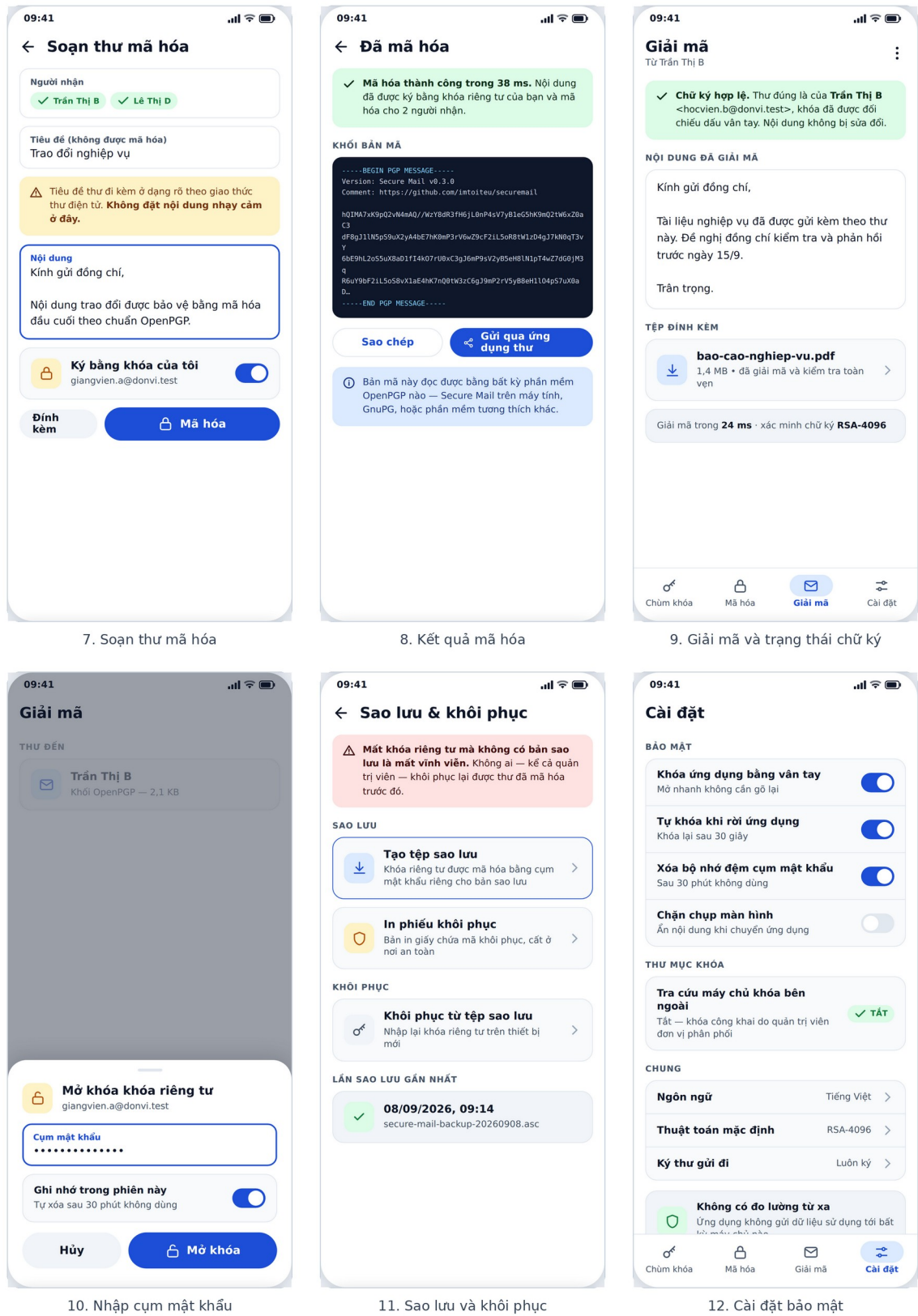
Ràng buộc "không đụng vào bản máy tính", biến thành phép kiểm tra tự động. Bản máy tính là bản tham chiếu đang hoạt động ổn định, phải giữ nguyên trong suốt quá trình phát triển bản di động. Tác giả biến cam kết này thành một kịch bản so khớp mã băm SHA-256 của **161 tệp** trong bản phát hành. Trong quá trình xây dựng hồ sơ, kịch bản đã **từ chối** ngay khi bản máy tính được sửa để gỡ thư viện đo lường — đúng như thiết kế.

Thiết kế giao diện Android. Giao diện được thiết kế theo Material 3, hoàn toàn bằng tiếng Việt, cho màn hình cảm ứng — **không phải bản thu nhỏ của giao diện**

máy tính. Mười hai màn hình phủ trọn vòng đời sử dụng và ánh xạ trực tiếp vào hợp đồng RPC ở Bảng 5.



Hình 8. Thiết kế giao diện Android — thiết lập và quản lý khóa



Hình 9. Thiết kế giao diện Android — mã hóa, giải mã, sao lưu và cài đặt

Bốn quyết định thiết kế đáng nêu, vì mỗi quyết định giải một vấn đề an toàn cụ thể chứ không phải lựa chọn thẩm mỹ:

- **Trạng thái tin cậy của khóa hiển thị ngay trong danh sách.** Khóa đã đối chiếu dấu vân tay mang dấu xanh; khóa chưa đối chiếu mang nhãn cảnh báo. Người dùng thấy được mức tin cậy trước khi chọn người nhận, thay vì phải nhớ. Đây là cách đưa bài toán khó nhất của mật mã khóa công khai lên bề mặt giao diện.
- **Cảnh báo về tiêu đề thư đặt ngay cạnh ô nhập.** Giới hạn kỹ thuật ở mục 3.b.1 được chuyển thành chỉ dẫn xuất hiện đúng lúc người dùng có thể mắc lỗi.
- **Kết quả xác minh chữ ký nói bằng ngôn ngữ người dùng:** thư đúng là của ai, khóa đã đối chiếu chưa, nội dung có bị sửa không — ba câu hỏi người dùng thực sự cần trả lời.
- **Cảnh báo mất khóa đặt tại màn hình sao lưu,** đúng chỗ người dùng ra quyết định.

Kiểm chứng trên đúng engine mà Android sử dụng. Vì WebView trên Android là Chromium, tác giả xây dựng thêm một phép thử nạp **đúng gói bundle mà ứng dụng Android sẽ nạp** vào Chromium và chạy trọn vòng đời qua hợp đồng RPC: khởi tạo lỗi, sinh hai cặp khóa RSA-4096, liệt kê chùm khóa, đọc chi tiết khóa, xuất khóa công khai, mã hóa kèm ký cho hai người nhận, giải mã kèm xác minh chữ ký, khóa lại và đọc tùy chọn. Gói bundle được phục vụ qua HTTP để chính sách CSP của trang có hiệu lực đúng như trong ứng dụng.

Bảng 6. Kết quả chạy lỗi mật mã trong Chromium — engine của Android System WebView

Nhóm phép thử	Kết quả
Nạp bundle và năng lực nền tảng (Web Crypto, TextEncoder, Web Streams)	ĐẠT
Khởi tạo lỗi và sinh hai cặp khóa RSA-4096	ĐẠT — 2.327 ms và 2.342 ms
Chùm khóa: liệt kê, đọc chi tiết, xuất khóa công khai	ĐẠT
Mã hóa kèm ký số cho hai người nhận	ĐẠT — 209 ms
Giải mã kèm xác minh chữ ký, tiếng Việt có dấu nguyên vẹn	ĐẠT — 549 ms
Liên thông: khóa và bản mã đọc được bằng thư viện độc lập ngoài WebView	ĐẠT
Khóa lại ứng dụng và mở khóa lại qua cầu RPC	ĐẠT
Tổng	16/16 ĐẠT

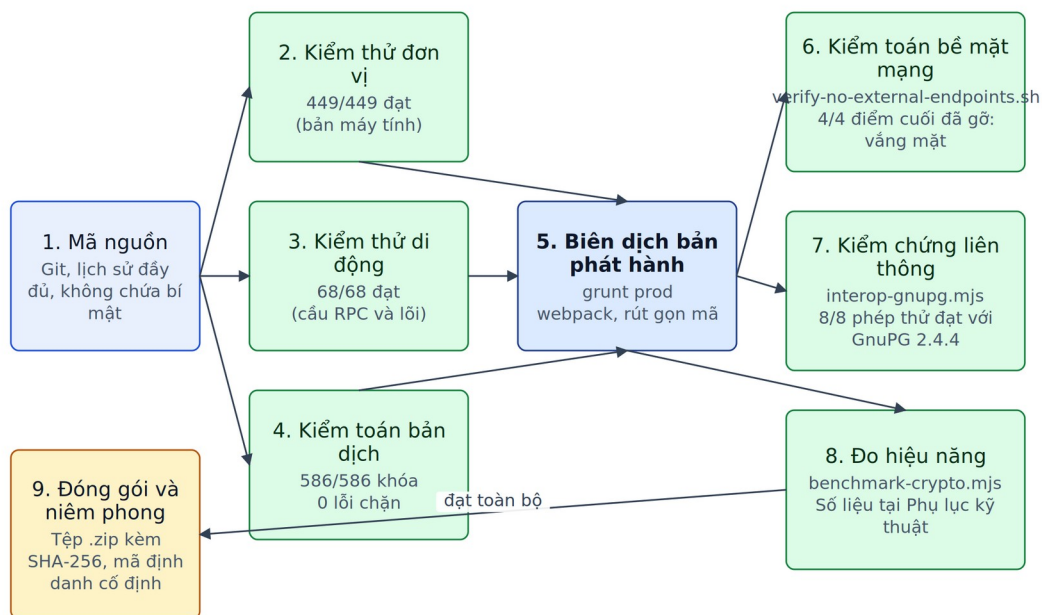
Phép thử này chứng minh lỗi mật mã của bản di động hoạt động đúng trên engine mà Android sử dụng, với chính gói bundle sẽ được đóng vào ứng dụng, và hai phép thử liên thông dùng một thư viện OpenPGP **độc lập chạy ngoài WebView** làm trọng tài nên kết quả không tự quy chiếu.

Nêu rõ giới hạn: phép thử **không** phủ tầng giao diện React Native, Android Keystore, quyền truy cập tệp, hành vi khi hệ điều hành thu hồi bộ nhớ và khác biệt giữa các phiên bản Android. Các hình giao diện ở trên là **bản thiết kế**, dựng ở đúng kích thước màn hình điện thoại thật (393×852) để kích thước chữ và vùng chạm là giá trị mà bước hiện thực phải đạt; chúng **chưa phải ảnh chụp một bản dựng đang chạy trên thiết bị**. Ma trận **38 phép thử trên thiết bị Android** đã được lập sẵn tại Phụ lục kỹ thuật mục G và sẽ được thực hiện ở giai đoạn 2.

3.b.7. Phương pháp kiểm chứng

Nguyên tắc xuyên suốt do tác giả đặt ra: **mọi khẳng định về an toàn phải có một lệnh chạy được để kiểm tra lại.**

Quy trình xây dựng và kiểm chứng một bản phát hành



Các bước 6, 7 và 8 đều là kịch bản chạy được, kết quả kèm trong hồ sơ. Người thẩm định chạy lại được trên chính bản phát hành để tự kiểm chứng, không phải tin vào lời khẳng định.

Hình 10. Quy trình xây dựng và kiểm chứng một bản phát hành

Bảng 7. Bộ công cụ kiểm chứng do tác giả xây dựng

Kịch bản	Kiểm tra điều gì	Kết quả trên v0.3.0
verify-no-external-endpoints.sh	Các điểm cuối đã gỡ không xuất hiện trở lại trong gói phát hành; liệt kê toàn bộ bề mặt mạng còn lại	ĐẠT — 4/4
interop-gnupg.mjs	Bản mã và chữ ký liên thông hai chiều với GnuPG; phát hiện bản mã bị sửa	ĐẠT — 8/8
benchmark-crypto.mjs	Đo thời gian sinh khóa, mã hóa, giải mã và độ giãn nở bản mã	Số liệu tại mục 3.c
verify-translation.mjs	Độ phủ, ô thay thế, thẻ đánh dấu, nhất quán thuật ngữ của bản dịch	ĐẠT — 586/586
verify-desktop-untouched.sh	Bản máy tính không bị thay đổi trong quá trình phát triển bản di động	ĐẠT — 161/161
webview-chromium.mjs	Lỗi mật mã của bản di động chạy đúng trong Chromium, engine của Android WebView	ĐẠT — 16/16

Bổ sung hai kịch bản phục vụ tài liệu hóa: chúng nạp **chính gói phát hành** vào trình duyệt và chụp lại giao diện, nên mọi ảnh chụp trong hồ sơ đều là ảnh của sản phẩm thật, tái tạo lại được. Bản phát hành được niêm phong bằng mã băm SHA-256.

c) Kết quả của giải pháp

3.c.1. Sản phẩm bàn giao

Bảng 8. Sản phẩm bàn giao

Hạng mục	Nội dung
Phần mềm	Secure Mail v0.3.0, Manifest V3, cho Chrome/Edge từ phiên bản 122
Mã định danh tiện ích	ihhialmbgcagicfabjkijsbpbppggbnebe (cố định trên mọi máy)
Gói cài đặt	secure-mail-v0.3.0-hardened.zip, 2,9 MB
Mã băm SHA-256	775bed7407df03b9c1f845300e2020e8f5d292e289419d6a8e65e7576558b106
Lỗi mật mã	OpenPGP.js 5.11.3, không sửa đổi
Ngôn ngữ	Tiếng Việt và tiếng Anh, người dùng chọn được; 14 ngôn ngữ khác vẫn hoạt động

Dự án phiên bản di động	Nền tảng hoàn chỉnh, 68/68 phép thử đạt; thiết kế 12 màn hình
Tài liệu vận hành tiếng Việt	9 tài liệu: cài đặt, hướng dẫn người dùng, quy trình quản lý khóa công khai, quy trình phát hành, danh mục kiểm tra an toàn, danh mục kiểm thử
Bộ công cụ kiểm chứng	5 kịch bản, 637 dòng

3.c.2. Danh mục chức năng

Sản phẩm bàn giao có **51 chức năng**, chia năm nhóm. Bảng dưới tổng hợp; danh mục chi tiết từng chức năng tại Phụ lục kỹ thuật, mục F.

Bảng 9. Tổng hợp danh mục chức năng

Nhóm chức năng	Tổng	Linh kiện sẵn có, giữ nguyên	Tác giả thiết kế lại	Tác giả xây dựng mới
Quản lý khóa	14	12	1	1
Mã hóa và giải mã	9	8	1	0
Tích hợp thư điện tử	9	5	4	0
An toàn và vận hành	13	8	1	4
Giao diện và ngôn ngữ	6	1	1	4
Tổng	51	34	8	9

Bảng này được đưa vào có chủ đích, kể cả khi nó cho thấy phần lớn chức năng đến từ linh kiện được chọn. Đó là sự thật, và nó **củng cố** chứ không làm yếu lập luận nền tảng ở đầu mục 3.b: giá trị của sáng kiến không nằm ở việc chế tạo lại 34 chức năng đã hoạt động tốt — làm vậy là phản kỹ thuật — mà ở **17 chức năng được thiết kế lại hoặc xây mới, chính là những chức năng quyết định sản phẩm có triển khai được trong đơn vị hay không.**

3.c.3. Kết quả kiểm thử

Bảng 10. Kết quả các bộ kiểm thử tự động, phân theo nguồn gốc

Bộ kiểm thử	Nguồn gốc	Chứng minh điều gì	Kết quả
Kiểm thử đơn vị bản máy tính — 22 nhóm	Kèm theo linh kiện nền tảng (tác giả sửa 3 phép thử)	Việc cải tạo không phá vỡ chức năng sẵn có	449/449 đạt

Kiểm thử bản di động — 10 nhóm	Tác giả xây dựng hoàn toàn	Lỗi mật mã chạy trên kiến trúc mới cho kết quả tương đương	68/68 đạt
Chạy lỗi mật mã trong Chromium — engine của Android WebView	Tác giả xây dựng	Gói bundle của ứng dụng Android hoạt động đúng trên đúng engine, có trọng tài độc lập	16/16 đạt
Kiểm chứng liên thông với GnuPG	Tác giả xây dựng	Bản mã là OpenPGP chuẩn, đọc được bằng phần mềm độc lập	8/8 đạt
Kiểm toán bề mặt mạng	Tác giả xây dựng	Các điểm cuối bên thứ ba đã gỡ, không xuất hiện trở lại	4/4 vắng mặt
Kiểm toán bản dịch — 586 chuỗi	Tác giả xây dựng	Bản dịch đầy đủ, nhất quán, không mất ô thay thế	0 lỗi chặn
Kiểm chứng bản máy tính không đổi	Tác giả xây dựng	161 tệp khớp mã băm	161/161

Nói rõ để tránh hiểu nhầm: **449 phép thử đơn vị đi kèm linh kiện nền tảng**, không phải công sức của tác giả. Giá trị của chúng trong hồ sơ này là bằng chứng **không hồi quy** — chính vì chúng không do người cải tạo viết ra nên mới chứng minh được rằng sau khi gỡ thư viện đo lường, gỡ cơ chế kiểm tra giấy phép, thay lớp đa ngữ và sửa luồng xác thực, toàn bộ chức năng sẵn có vẫn hoạt động đúng.

3.c.4. Kết quả kiểm chứng tính liên thông

Giá trị của giải pháp phụ thuộc vào việc bản mã của nó là **OpenPGP chuẩn**, không phải định dạng riêng: thư mã hóa hôm nay phải đọc được bằng bất kỳ phần mềm tuân thủ chuẩn nào, kể cả khi Secure Mail không còn được dùng. Đây là điều kiện để dữ liệu của đơn vị không bị khóa vào một sản phẩm.

Kịch bản do tác giả xây dựng chứng minh điều này bằng cách trao đổi thư thật hai chiều với **GnuPG 2.4.4** — phần mềm mật mã tham chiếu, độc lập hoàn toàn về mã nguồn và về tổ chức phát triển. Nội dung thử là văn bản tiếng Việt có dấu.

Bảng 11. Kết quả kiểm chứng liên thông với GnuPG 2.4.4

Phép thử	Kết quả
Nhập khóa hai chiều (RSA-4096)	ĐẠT
A. Tính bí mật: Secure Mail → GnuPG, bản rõ đúng từng byte, tiếng Việt nguyên vẹn	ĐẠT

A. Tính xác thực: GnuPG báo chữ ký hợp lệ	ĐẠT
B. Tính bí mật: GnuPG → Secure Mail, bản rõ đúng từng byte	ĐẠT
B. Tính xác thực: Secure Mail xác minh đúng chữ ký của GnuPG	ĐẠT
C. Chữ ký tách rời do Secure Mail tạo, GnuPG xác minh được	ĐẠT
D. Tính toàn vẹn: đổi một ký tự trong bản mã → bị từ chối, không trả về bản rõ sai	ĐẠT
Tổng	8/8 ĐẠT

Phép thử D đáng chú ý về phương pháp: nó chứng minh một **thuộc tính an toàn tiêu cực** — hệ thống *từ chối* dữ liệu bị sửa thay vì âm thầm cho ra kết quả sai. Với hệ thống mật mã, thất bại đúng cách quan trọng ngang thành công đúng cách.

3.c.5. Các thông số, chỉ tiêu kỹ thuật đạt được

Đo trên máy chủ xây dựng (AMD EPYC, 4 nhân, 7,8 GB RAM), dùng đúng thư viện mà bản phát hành đóng gói. Mỗi giá trị là **trung vị** của nhiều lần chạy. Số liệu đầy đủ tại Phụ lục kỹ thuật, mục B.

Bảng 12. Các chỉ tiêu kỹ thuật đo được

Chỉ tiêu	Giá trị
Sinh cặp khóa RSA-4096 (thư viện thuần)	2.785 ms
Sinh cặp khóa RSA-4096 qua giao diện thật	8,1 – 10,2 giây (chỉ thực hiện một lần khi thiết lập)
Sinh cặp khóa RSA-2048 / ECC Curve25519	428 ms / 306 ms
Mã hóa kèm ký một bức thư tiêu biểu (~5 KB)	36 ms
Giải mã kèm xác minh chữ ký	19 ms
Mã hóa tệp đính kèm 1 MB / 5 MB	115 ms / 404 ms
Giải mã tệp đính kèm 1 MB / 5 MB	26 ms / 87 ms
Độ giãn nở bản mã (dữ liệu lớn, trường hợp xấu nhất)	~36%
Kích thước tệp đính kèm gốc lớn nhất gửi được qua Gmail	~18 MB
Độ phủ bản dịch tiếng Việt	586/586 = 100%

Nhận xét: **với thư điện tử thông thường, độ trễ do mã hóa là 15–36 mili giây — dưới ngưỡng cảm nhận của con người**, người dùng không thấy sản phẩm chậm đi; với tệp đính kèm 5 MB, tổng thời gian dưới nửa giây. Độ giãn nở ~36% là hệ quả

của mã hóa Base64 (tự nó đã tăng 33%) để khối bản mã đi qua được hệ thống thư điện tử vốn chỉ bảo đảm truyền văn bản; các phép đo dùng dữ liệu ngẫu nhiên không nên được nên đây là **trường hợp xấu nhất**, thư văn bản thật nén được nhiều hơn.

Về bản địa hóa, tiếng Việt là ngôn ngữ **duy nhất đạt độ phủ 100%** ngoài tiếng Anh — cao hơn cả tiếng Đức (579/586), Ukraina và Pháp (534), Nhật (528). Đây không phải con số so bì mà là chỉ tiêu chất lượng có ý nghĩa thực tế: bất kỳ chuỗi nào thiếu đều rơi về tiếng Anh, và với người dùng không thạo tiếng Anh thì một thông báo lỗi tiếng Anh xuất hiện đúng lúc gặp sự cố là lúc tệ nhất.

4. Tự đánh giá giải pháp

a) Tính mới và tính sáng tạo

Điểm mới

Trước khi liệt kê, trả lời thẳng câu hỏi mà một hội đồng nghiêm khắc chắc chắn đặt ra:

"**Đây có phải chỉ là dịch giao diện một phần mềm nguồn mở sang tiếng Việt?**" Không. Phép thử đơn giản nhất: **nếu chỉ dịch mà không làm gì khác, sản phẩm có triển khai được không?** Không. Tài khoản Google Workspace của cơ quan sẽ bị chặn bởi cơ chế kiểm tra giấy phép; luồng xác thực thất bại vì mã định danh tiện ích thay đổi theo từng máy; và mỗi lần soạn thư cho một địa chỉ mới sẽ phát sinh một truy vấn ra máy chủ khóa ở nước ngoài. Ngay cả bản dịch cũng **không thực hiện được** nếu không thiết kế lại lớp đa ngữ trước, vì linh kiện nền tảng khóa cứng ngôn ngữ theo trình duyệt.

Điểm mới 1 — Trình khách OpenPGP hoàn chỉnh bằng tiếng Việt kèm hệ thuật ngữ mật mã chuẩn hóa. Theo khảo sát tại mục 1.3, chưa có trình khách mã hóa thư điện tử đầu cuối nào có giao diện tiếng Việt hoàn chỉnh. Sáng kiến tạo ra bản dịch 586/586 chuỗi, độ phủ 100%, kèm bộ thuật ngữ được chuẩn hóa và **kiểm tra nhất quán bằng công cụ**. Đóng góp không dừng ở phần mềm: bộ thuật ngữ tại Bảng 4 là kết quả cân nhắc từng khái niệm theo tiêu chí sự phạm, dùng lại được cho giáo trình và các phần mềm khác.

Điểm mới 2 — Thuật toán phân giải ngôn ngữ vượt giới hạn kiến trúc của nền tảng. Thuật toán bốn bước tại mục 3.b.5 cho phép người dùng chọn ngôn ngữ độc lập với trình duyệt **mà không phá vỡ** cơ chế đa ngữ sẵn có cho 14 ngôn ngữ còn lại. Đây là điểm mới về kỹ thuật và là **điều kiện cần** để bản dịch có tác dụng trong thực tế.

Điểm mới 3 — Mô hình tin cậy khép kín do đơn vị kiểm soát. Thay mô hình "tra cứu máy chủ khóa công cộng, tin theo TOFU" bằng mô hình "phân phối khóa khép kín, xác nhận danh tính qua kênh nội bộ đã xác thực", kèm quy trình quản trị được tài liệu hóa và mẫu danh mục khóa. Đây là thay đổi về **mô hình an toàn**, không phải về cấu hình: nó loại bỏ một kênh rò rỉ siêu dữ liệu quan hệ liên lạc và đặt trách nhiệm xác nhận danh tính vào đúng chỗ.

Điểm mới 4 — Loại bỏ triệt để phụ thuộc bên thứ ba, kiểm chứng được trên gói phát hành. Kết quả là sản phẩm ở cấu hình mặc định **không liên lạc với máy chủ nào ngoài chính Gmail**, và điều đó **kiểm tra lại được bằng một lệnh**. Riêng việc gỡ cơ chế kiểm tra giấy phép còn **mở khóa khả năng sử dụng cho tài khoản Google Workspace** — chính là loại tài khoản mà một cơ quan sẽ dùng, vốn bị chặn.

Điểm mới 5 — Thiết kế luồng xác thực an toàn và triển khai được. Định danh tiện ích tắt định biến một thuộc tính ngẫu nhiên theo môi trường thành **hằng số triển khai**, đồng thời tạo ra một đại lượng kiểm chứng được để phát hiện bản cài đặt giả mạo. PKCE là biện pháp thực sự bảo vệ luồng xác thực trong mô hình đe dọa của tiện ích trình duyệt.

Điểm mới 6 — Kiến trúc mở rộng sang di động giữ nguyên lõi mật mã đã kiểm chứng. Cách làm thông thường là viết lại phần mật mã bằng thư viện của nền tảng, kéo theo rủi ro sai lệch hành vi không kiểm chứng được. Kiến trúc "giao diện gốc + WebView chạy lõi mật mã + cầu RPC có kiểu" nạp mã nguồn lõi **nguyên vẹn không sửa một dòng**, kèm hợp đồng 22 phương thức và thiết kế 12 màn hình. Sự tương đương được chứng minh bằng bộ phép thử đối chứng và bằng việc chạy chính gói bundle của ứng dụng trên **đúng engine mà Android sử dụng** — 16/16 phép thử đạt, có trọng tài độc lập ngoài WebView.

Điểm sáng tạo

Tính mới nói về *cái gì* được tạo ra. Tính sáng tạo nói về *cách* đi tới đó. Bốn điểm dưới đây là phần đóng góp mà tác giả cho là có giá trị lâu dài nhất.

1. Biện khẳng định an toàn thành phép kiểm tra chạy lại được. Trong tài liệu về sản phẩm bảo mật, những câu như "không thu thập dữ liệu người dùng", "mã hóa đầu cuối" xuất hiện thường xuyên và gần như không bao giờ kiểm chứng được — người đọc chỉ có thể tin hoặc không tin. Tác giả áp dụng nguyên tắc ngược lại: **mỗi khẳng định phải đi kèm một lệnh để bác bỏ nó**. Cách làm này đảo ngược gánh nặng chứng minh: người thẩm định không phải tin tác giả mà tự kiểm tra được. Phương pháp này áp dụng được cho bất kỳ hồ sơ sản phẩm an toàn thông tin nào và có giá trị vượt ra ngoài phạm vi sáng kiến này.

Chính phương pháp đó đã tự phát hiện lỗi trong sản phẩm: **sáu lỗi dịch thuật, trong đó hai lỗi làm mất khuyến cáo an toàn, và ba phép thử hồng**. Một quy trình chỉ tìm thấy điều tốt đẹp là một quy trình không hoạt động.

2. Kỷ luật "không sửa cái không cần sửa". Cắm đố lớn trong một sáng kiến kỹ thuật là làm nhiều để có vẻ đóng góp nhiều. Với phần mềm mật mã, đó là hướng sai. Tác giả áp dụng ranh giới rõ ràng: **thay đổi mọi thứ cản trở việc triển khai; không đụng vào lỗi mật mã đã được kiểm chứng**. Chính vì giữ nguyên định dạng dữ liệu mà phép thử liên thông với GnuPG mới đạt 8/8. Kỷ luật này được ghi thành quy tắc bắt buộc trong tài liệu dự án và được bảo đảm bằng kiểm tra mã băm 161 tệp.

3. Chọn đúng biện pháp cho đúng mô hình đe dọa. Vấn đề bí mật client (mục 3.b.4) minh họa rõ: thay vì tìm cách giấu kỹ hơn một thứ về nguyên tắc không giấu được, tác giả phân tích *biện pháp này bảo vệ chống lại điều gì* rồi bổ sung một biện pháp khác thực sự phù hợp. Cùng cách tiếp cận dẫn tới quyết định gỡ bỏ hẳn thay vì tắt bằng cấu hình ở mục 3.b.3: nếu mô hình đe dọa bao gồm cả một lần cập nhật vô ý, thì một hằng số `false` không phải là biện pháp bảo vệ.

4. Dùng chính sản phẩm làm học cụ. Với vai trò giảng viên, tác giả thiết kế phần bản địa hóa theo tiêu chí sư phạm chứ không chỉ tiêu chí dịch thuật: thuật ngữ song ngữ có chủ đích ở lần xuất hiện đầu để học viên nối được với tài liệu chuyên môn; ba nguyên tắc an toàn cốt lõi đưa vào chính màn hình thiết lập thay vì để trong tài liệu không ai đọc; và sản phẩm dùng thật cũng là bài thực hành — học viên sinh khóa, đối chiếu dấu vân tay, cố ý sửa một ký tự trong bản mã để thấy hệ thống từ chối. Những thao tác trừu tượng trên bảng trở thành thao tác nhìn thấy được.

b) Khả năng áp dụng

Điều kiện triển khai. Rào cản được giữ ở mức thấp nhất — đây là mục tiêu thiết kế, không phải may mắn. *Hạ tầng:* không cần máy chủ, không hệ thống chứng thực số, không thay đổi hệ thống thư điện tử hiện có. *Phần mềm:* trình duyệt Chrome hoặc Edge từ phiên bản 122, đã có sẵn trên hầu hết máy trạm. *Cài đặt:* giải nén và nạp vào trình duyệt, có hướng dẫn tiếng Việt kèm ảnh minh họa. *Nhân sự:* một quản trị viên khóa cho mỗi đơn vị, làm nhiệm vụ đối chiếu dấu vân tay và phát hành danh mục khóa công khai; không đòi hỏi trình độ chuyên gia mật mã, quy trình đã tài liệu hóa từng bước. *Đào tạo người dùng:* ước tính khoảng một buổi, dựa trên số bước thao tác thực

tế; con số này **chưa được kiểm chứng qua đào tạo thực tế** và cần xác nhận khi triển khai.

Đối tượng áp dụng.

- **Giảng dạy và học tập** — nhóm sẵn sàng áp dụng ngay, vì môi trường đã sẵn có và không có rào cản pháp lý: học cụ thực hành mật mã khóa công khai, chữ ký số, quản lý khóa và mô hình tin cậy trong các học phần An toàn thông tin, Mật mã ứng dụng, An ninh mạng; bảo vệ đề cương, đề thi chưa công bố, đáp án, kết quả học tập; trao đổi bản thảo đồ án, luận văn.
- **Trao đổi nghiệp vụ nội bộ** — thông tin cần bảo vệ nhưng không thuộc danh mục bí mật nhà nước, theo quy chế của đơn vị.
- **Nghiên cứu khoa học** — trao đổi dữ liệu, bản thảo, kết quả chưa công bố giữa các nhóm nghiên cứu.
- **Nhân rộng** — vì không đòi hỏi hạ tầng, giải pháp áp dụng được ở các nhà trường, học viện, cơ quan khác có nhu cầu tương tự. Mã nguồn, tài liệu và bộ thuật ngữ đều dùng lại được.

Giới hạn của khả năng áp dụng. Trình bày rõ để tránh kỳ vọng sai: giải pháp **chỉ có tác dụng khi cả hai đầu cùng dùng** — người nhận có thể dùng bất kỳ phần mềm OpenPGP nào (đã chứng minh liên thông với GnuPG), nhưng không thể là người không dùng gì; **chưa bảo vệ siêu dữ liệu; chưa có ứng dụng di động hoàn chỉnh** (nền tảng đã xong và kiểm chứng được, giao diện là giai đoạn tiếp theo); và có ràng buộc pháp lý về phạm vi dữ liệu (mục 4.đ).

c) Hiệu quả

Hiệu quả kỹ thuật

Đây là nhóm hiệu quả **đã đo được**, so sánh trực tiếp với linh kiện nền tảng ở trạng thái nguyên bản.

Bảng 13. So sánh chỉ tiêu kỹ thuật trước và sau

Chỉ tiêu	Linh kiện nền tảng	Secure Mail v0.3.0	Ý nghĩa
Ngôn ngữ tiếng Việt	Không có	586/586 chuỗi, 100%	Dùng được không cần tiếng Anh
Người dùng chọn ngôn ngữ	Không (khóa theo trình duyệt)	Có, 3 lựa chọn	Không phụ thuộc cấu hình trình duyệt

Tra cứu máy chủ khóa bên ngoài	3 cơ chế bật mặc định	4 cơ chế tắt mặc định	Không rò rỉ quan hệ liên lạc
Thư viện đo lường từ xa trong gói	Có (9 lần xuất hiện)	Không có (0)	Không có kênh thu thập dữ liệu
Kiểm tra giấy phép gọi ra bên thứ ba	Có	Không có (0)	Tài khoản Workspace dùng được; không phụ thuộc dịch vụ thương mại
PKCE bảo vệ luồng xác thực	Không	Có (S256, RFC 7636)	Mã ủy quyền bị chặn không dùng được
Định danh tiện ích	Thay đổi theo máy	Cố định	Triển khai được; kiểm chứng được bản cài
Bộ công cụ kiểm chứng đi kèm	Không	5 kịch bản	Khả năng định an toàn kiểm tra lại được
Kiến trúc di động	Không	Nền tảng hoàn chỉnh, 68/68 đạt; lõi chạy đúng trên engine Android, 16/16 đạt	Mở đường cho giai đoạn 2
Liên thông OpenPGP chuẩn	Có	Có — kiểm chứng 8/8 với GnuPG	Dữ liệu không bị khóa vào sản phẩm

Về hiệu năng, số liệu tại Bảng 12 cho thấy chi phí tính toán của mã hóa **không phải là trở ngại sử dụng**.

Hiệu quả kinh tế

Sáng kiến chưa được triển khai diện rộng, nên chưa có hiệu quả kinh tế đã thực hiện để báo cáo. Phần dưới đây là *dự kiến*, nêu rõ căn cứ; chi tiết tại tài liệu *Dự kiến hiệu quả khi đưa vào ứng dụng trong thực tiễn*.

Chi phí trực tiếp bằng không: không phát sinh chi phí bản quyền phần mềm (giấy phép AGPL-3.0, sử dụng nội bộ phi thương mại), không chi phí máy chủ, không chi phí thiết bị. Chi phí bằng không là **kết quả của thiết kế** — giải pháp cố ý được xây dựng để không cần máy chủ, không cần chứng thư số, không cần đối nhà cung cấp thư, vì mỗi thứ đó đều là một rào cản triển khai.

Chi phí tránh được so với các phương án thay thế: phí thuê bao dịch vụ thư điện tử bảo mật theo người dùng theo năm, cùng chi phí di chuyển dữ liệu và đào tạo lại; đầu tư hệ thống chứng thực số và chi phí cấp, gia hạn chứng thư nếu triển khai S/MIME; phí giấy phép thương mại theo người dùng theo tháng nếu dùng linh kiện nền tảng nguyên bản với tài khoản Workspace; chi phí đặt hàng phát triển phần mềm

tương đương. Hồ sơ **không quy đổi các khoản này thành tiền** vì việc quy đổi đòi hỏi số người dùng thực tế — hiện chưa có.

Hiệu quả về quốc phòng — an ninh và xã hội

Thu hẹp bề mặt rò rỉ thông tin. Với thư điện tử thông thường, nội dung tồn tại ở dạng rõ trên hạ tầng nhà cung cấp suốt thời gian lưu trữ. Với Secure Mail, nội dung ở dạng bản mã và khóa giải mã không tồn tại ở bất kỳ đâu ngoài máy trạm người dùng. Đây là thay đổi **về bản chất**, không phải về mức độ.

Loại bỏ rò rỉ siêu dữ liệu quan hệ. Tắt toàn bộ tra cứu máy chủ khóa bên ngoài loại bỏ một kênh mà qua đó tập hợp quan hệ liên lạc của đơn vị có thể bị thu thập ở nước ngoài. Với công tác bảo vệ nội bộ, thông tin "ai thường liên lạc với ai" có giá trị độc lập với nội dung liên lạc.

Giảm phụ thuộc vào nhà cung cấp nước ngoài. Sau khi gỡ hai kênh liên lạc ra bên thứ ba, khả năng đọc dữ liệu đã mã hóa của đơn vị không còn phụ thuộc vào bất kỳ dịch vụ nào ngoài hạ tầng thư mà đơn vị chủ động chọn. Kể cả khi mất kết nối Internet, thư đã tải về vẫn giải mã được bằng khóa lưu tại máy.

Nâng cao năng lực làm chủ công nghệ. Toàn bộ mã nguồn nằm trong tầm kiểm soát của đơn vị: đọc được, sửa được, biên dịch lại được từ mã nguồn. Đây là điều kiện cần để một sản phẩm an toàn thông tin được tin dùng — không có "hộp đen".

Đóng góp vào đào tạo nhân lực an toàn thông tin. Hiệu quả gián tiếp nhưng lâu dài nhất. Học viên được thực hành mật mã ứng dụng trên công cụ thật, bằng tiếng Việt, với hệ thuật ngữ thống nhất giữa bài giảng và phần mềm. Một bộ phận trong số họ sẽ là cán bộ bảo đảm an toàn thông tin của các đơn vị trong tương lai.

Hiệu quả xã hội. Bộ thuật ngữ mật mã tiếng Việt là tài sản dùng lại được cho giáo trình, bài giảng và các phần mềm khác. Việc hạ rào cản ngôn ngữ có tác dụng vượt ra ngoài phạm vi một đơn vị.

d) Mức độ triển khai, phát triển trong thời gian tới

Bảng 14. Trạng thái các hạng mục

Hạng mục	Trạng thái
Tiện ích máy tính: mã hóa, giải mã, ký, xác minh, quản lý khóa	Hoàn thành, đã kiểm thử

Tích hợp Gmail (giao diện web và Gmail API)	Hoàn thành, đã kiểm thử
Bản địa hóa tiếng Việt và bộ chọn ngôn ngữ	Hoàn thành — 586/586, 0 lỗi chặn
Mô hình tin cậy khép kín và cắt phụ thuộc bên thứ ba	Hoàn thành, kiểm chứng 4/4
Xác thực OAuth với định danh cố định và PKCE	Hoàn thành
Bộ công cụ kiểm chứng	Hoàn thành — 5 kịch bản
Tài liệu vận hành tiếng Việt	Hoàn thành — 9 tài liệu
Phiên bản di động: nền tảng kỹ thuật	Hoàn thành — 68/68 phép thử đạt
Phiên bản di động: kiểm chứng lỗi trên engine của Android WebView	Hoàn thành — 16/16 phép thử đạt
Phiên bản di động: thiết kế giao diện	Hoàn thành — 12 màn hình
Phiên bản di động: hiện thực giao diện và kiểm thử trên thiết bị	Giai đoạn 2
Tích hợp Gmail trên di động	Giai đoạn 2
Phiên bản iOS	Giai đoạn 3
Triển khai thí điểm và đánh giá thực tế	Chưa thực hiện

Giai đoạn 1 — Triển khai thí điểm. Việc cần làm ngay và quan trọng nhất, vì nó bổ sung phần còn thiếu quyết định của hồ sơ: số liệu sử dụng thực tế. Nội dung: triển khai cho một nhóm người dùng, tổ chức tập huấn, thiết lập quy trình quản lý khóa công khai của đơn vị, ghi nhận vướng mắc, đo thời gian đào tạo thực tế và tỷ lệ thao tác thành công.

Giai đoạn 2 — Hoàn thiện ứng dụng Android. Hiện thực giao diện đã thiết kế trên nền cầu RPC và lỗi mật mã đã kiểm chứng; thực hiện ma trận kiểm thử trên thiết bị tại Phụ lục kỹ thuật mục G; bổ sung tích hợp Gmail trên di động với luồng OAuth riêng cho ứng dụng Android dùng PKCE không kèm bí mật client.

Giai đoạn 3 — Mở rộng. Phiên bản iOS (kiến trúc đã thiết kế để không phải viết lại); hỗ trợ thêm nhà cung cấp thư ngoài Gmail; nghiên cứu vận hành máy chủ khóa nội bộ hoặc Web Key Directory trên tên miền của đơn vị để tự động hóa phân phối khóa công khai mà vẫn giữ nguyên tắc khép kín.

Giai đoạn 4 — Nếu có nhu cầu và được phê duyệt. Đưa sản phẩm ra đánh giá an toàn độc lập; nghiên cứu khả năng tích hợp với sản phẩm mật mã của cơ quan có thẩm quyền để mở rộng phạm vi dữ liệu áp dụng.

Bảo đảm duy trì khi tác giả không còn trực tiếp phụ trách. Một sản phẩm chỉ một người hiểu là một rủi ro, không phải một thành tựu. Đây là lý do phần lớn công sức được đầu tư vào những thứ bàn giao được: mã nguồn đầy đủ trong hệ thống quản lý phiên bản với lịch sử ghi rõ lý do từng thay đổi; quy trình dừng lại được ghi thành lệnh cụ thể; bộ kịch bản kiểm chứng cho phép người tiếp nhận tự xác nhận sản phẩm còn đúng sau mỗi lần sửa mà không cần hiểu toàn bộ mã nguồn; chín tài liệu vận hành bằng tiếng Việt; và lỗi mật mã không bị sửa nên người tiếp nhận chỉ cần hiểu phần thiết kế của tác giả.

đ) Phạm vi áp dụng và giới hạn — trình bày trung thực

Mục này được viết ra để hồ sơ không đưa ra bất kỳ khẳng định nào vượt quá cơ sở thực tế. Tác giả cho rằng chính sự chính xác này làm hồ sơ đáng tin cậy hơn.

Cần phân biệt rõ ba điều thường bị đồng nhất: **năng lực kỹ thuật** của giải pháp — điều sáng kiến đã chứng minh bằng đo đạc và kiểm thử; **tiềm năng ứng dụng** — điều giải pháp có thể làm nếu được đầu tư và phê duyệt tiếp; và **tư cách pháp lý** để sử dụng cho một loại thông tin cụ thể — điều **không do năng lực kỹ thuật quyết định** mà do quy định pháp luật và cơ quan có thẩm quyền quyết định. Hồ sơ này khẳng định mức thứ nhất, đề xuất mức thứ hai, và **không đưa ra bất kỳ khẳng định nào ở mức thứ ba.**

Phạm vi dữ liệu phù hợp và ranh giới pháp lý



Hình 11. Phạm vi dữ liệu phù hợp và ranh giới pháp lý

Secure Mail chưa được kiểm định, chưa được cấp phép và không được đề xuất sử dụng để truyền, nhận thông tin thuộc danh mục bí mật nhà nước. Việc chuyển, nhận tài liệu, vật chứa bí mật nhà nước qua mạng Internet, mạng máy tính và mạng viễn thông phải được thực hiện theo quy định của pháp luật về cơ yếu và phải sử dụng sản phẩm mật mã do cơ quan có thẩm quyền cung cấp — Luật Bảo vệ bí mật nhà nước năm 2018; Nghị định số 26/2020/NĐ-CP ngày 28/02/2020. Việc một giải pháp sử dụng thuật toán mạnh và được kiểm thử kỹ **không tự nó tạo ra tư cách pháp lý** cho mục đích trên.

Phạm vi áp dụng được đề xuất giới hạn ở **thông tin cần được bảo vệ nhưng không thuộc danh mục bí mật nhà nước**: tài liệu giảng dạy, đề thi chưa công bố, kết quả học tập, dữ liệu cá nhân của học viên, tài liệu nghiên cứu chưa công bố, trao đổi nghiệp vụ nội bộ theo quy chế của đơn vị.

Những giới hạn kỹ thuật khác, liệt kê đầy đủ:

- **Siêu dữ liệu không được bảo vệ.** Người gửi, người nhận, thời gian, kích thước và **tiêu đề thư** vẫn hiển thị với nhà cung cấp. Hệ quả thực tế cho quy chế sử dụng:

không đặt nội dung nhạy cảm vào tiêu đề thư — điều này đã được đưa vào tài liệu hướng dẫn và vào chính giao diện.

- **An toàn phụ thuộc vào máy trạm.** Nếu máy trạm bị nhiễm mã độc ghi phím hoặc đọc bộ nhớ, mã hóa đầu cuối không bảo vệ được. Đây là giới hạn nền tảng của mọi giải pháp mã hóa phía người dùng; giải pháp phải đi cùng các biện pháp bảo vệ máy trạm hiện hành, không thay thế chúng.
- **Mất khóa riêng tư mà không có bản sao lưu là mất vĩnh viễn thư cũ.** Không có cơ chế khôi phục tập trung — hệ quả tất yếu của việc quản trị viên không giữ khóa riêng tư, vì nếu giữ thì mô hình mã hóa đầu cuối sụp đổ. Sản phẩm bù lại bằng chức năng sao lưu, phiếu khôi phục và cảnh báo bằng tiếng Việt ngay trong giao diện tại thời điểm người dùng vừa tạo khóa. Nếu đơn vị có yêu cầu khôi phục tập trung, cần thiết kế bổ sung và phải cân nhắc kỹ vì nó thay đổi mô hình an toàn.
- **Chưa qua đánh giá an toàn độc lập.** Toàn bộ kiểm thử trong hồ sơ do tác giả thực hiện — và chính vì vậy tác giả cung cấp kèm bộ kịch bản để bên thứ ba chạy lại.
- **Chưa triển khai diện rộng.** Chưa có số liệu người dùng thực tế; các mục này trong hồ sơ được để trống có đánh dấu.
- **Phụ thuộc vào giao diện web của Gmail.** Phần chèn giao diện bám vào cấu trúc trang; khi Google thay đổi lớn, phần này cần cập nhật. **Phần lõi mật mã không bị ảnh hưởng** — trong trường hợp xấu nhất, người dùng vẫn mã hóa và giải mã được qua trang tùy chọn rồi dán kết quả vào Gmail; thư đã mã hóa không bao giờ trở nên không đọc được.
- **Bản di động chưa hoàn chỉnh.** Nền tảng và thiết kế đã xong; hiện thực giao diện là giai đoạn tiếp theo.

KẾT LUẬN

Sáng kiến giải quyết một vấn đề có thật trong công tác giảng dạy và bảo đảm an toàn thông tin của đơn vị: nhu cầu bảo vệ nội dung trao đổi qua thư điện tử, và nhu cầu có công cụ thực hành mật mã ứng dụng bằng tiếng Việt.

Giá trị của giải pháp không nằm ở việc chế tạo lại một thuật toán mật mã — đó là hướng đi phản kỹ thuật và làm giảm độ an toàn thực tế. Giá trị nằm ở **thiết kế hệ thống**: xác định đúng bài toán và bốn điều kiện ràng buộc, lựa chọn linh kiện đã được

kiểm chứng cho đúng vị trí, rồi thiết kế toàn bộ phần còn lại — mô hình tin cậy, kiến trúc bản địa hóa, luồng xác thực, kiến trúc mở rộng di động và phương pháp kiểm chứng — để biến những cơ chế mật mã đã có thành một sản phẩm **triển khai được trong điều kiện thực tế của đơn vị**.

Điểm mà tác giả coi trọng nhất: **mọi khẳng định về an toàn trong hồ sơ này đều có một lệnh để người khác kiểm tra lại**. Toàn bộ số liệu đều đo được và tái lập được; những gì chưa có cơ sở thực tế đều được ghi rõ là chưa có, thay vì được ước lượng thành con số.

CÁN BỘ THỰC HIỆN

(Ký, ghi rõ họ tên)

THỦ TRƯỞNG ĐƠN VỊ CHỦ TRÌ

THỰC HIỆN

(Ký, đóng dấu)